EFREI PARIS · SÉCURITÉ DES RÉSEAUX

MediConnect

Architecture réseau sécurisée

Rapport de projet

ÉTUDIANT	**Daniel ALEKSIC**
PROMOTION	2028
GROUPE	CIL
ENSEIGNANT	Salim BENAYOUNE
DATE	Octobre 2026

Projet du cours de sécurité des réseaux.

Table des matières

1 Contexte et périmètre . . . 3

2 Architecture retenue . . . 4

2.1 Schéma d'ensemble . . . 4

2.2 Choix techniques . . . 5

2.3 Plan d'adressage . . . 5

3 Zones de sécurité et niveaux de confiance . . . 7

4 VPN et authentification . . . 8

4.1 VPN site à site (IPsec) . . . 8

4.2 VPN d'accès distant (OpenVPN) . . . 9

4.3 PKI . . . 11

4.4 Authentification . . . 12

5 Politique de filtrage . . . 17

5.1 Principes et alias . . . 17

5.2 Règles de filtrage par interface . . . 18

5.3 Règles basées sur l'identité . . . 22

5.4 Contrôle applicatif . . . 24

6 Protection de la DMZ . . . 27

7 Sécurisation de l'administration . . . 29

8 Journalisation et supervision . . . 31

9 Tests réalisés . . . 35

10 Limites de la solution . . . 38

11 Conclusion . . . 38

1 Contexte et périmètre

Vidéo : https://drive.google.com/file/d/16hm2hC1me6qMWFsJVCqMqHFy-5lVpPcL/view?usp=sharing

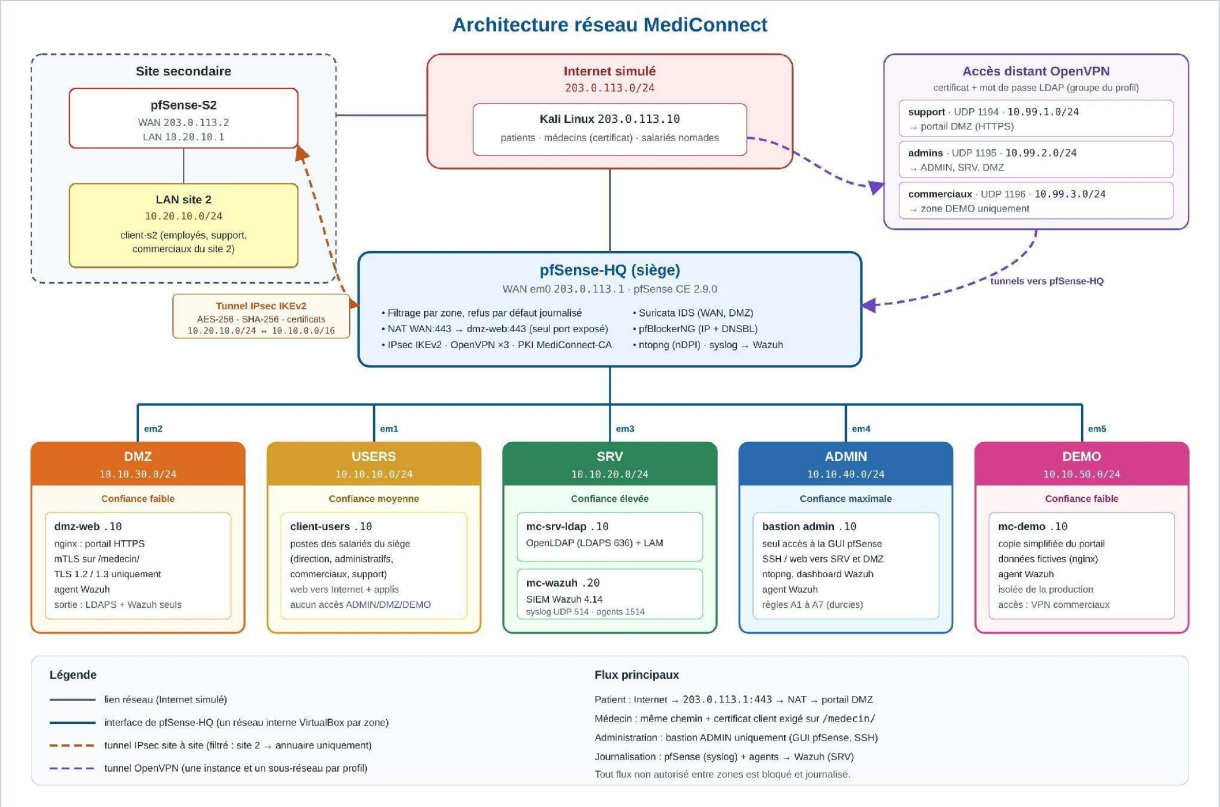
MediConnect souhaite lancer une plateforme de prise de rendez-vous médicaux concurrente de Doctolib. Dans ce projet, l'application web est considérée comme existante et la solution que je propose porte uniquement sur l'architecture réseau (segmentation, VPN, pare-feu, authentification, contrôle applicatif et supervision).

L'infrastructure a été maquettée sous VirtualBox. Elle comprend deux pare-feu pfSense CE (siège et site secondaire), sept machines Ubuntu (postes et serveurs) et une machine Kali Linux qui joue le rôle d'un hôte d'Internet (patient, médecin ou salarié en déplacement). Le portail MediConnect est simulé par un serveur nginx. Le tableau ci-dessous met en correspondance les objectifs du sujet et les mécanismes retenus.

Objectif du sujet	Mise en œuvre	Section
Interconnexion sécurisée des deux sites	Tunnel IPsec IKEv2 authentifié par certificats, filtré à l'arrivée	4.1
Accès distant des employés	OpenVPN, une instance par profil (support, admins)	4.2, 5.3
Accès distant des commerciaux	Instance OpenVPN dédiée, limitée à la zone DEMO	4.2, 5.3
Accès Internet des patients	Redirection du seul port 443 vers le portail en DMZ	6
Accès authentifié des médecins	Certificat client exigé par nginx (mTLS) sur /medecin/	4.4.4
Exposition sécurisée de la plateforme	DMZ isolée, HTTPS uniquement, IDS Suricata	6
Séparation production / démonstration	Zone DEMO isolée de tous les réseaux privés	5.2, 9
Contrôle applicatif	Suricata, pfBlockerNG (IP et DNSBL), ntopng (nDPI)	5.4
Politiques selon l'identité	Groupe LDAP, instance OpenVPN, règles par sous-réseau de tunnel	5.3
Administration sécurisée	Zone ADMIN dédiée, seule autorisée à administrer	7
Journalisation	Syslog pfSense et agents vers le SIEM Wazuh	8

2 Architecture retenue

2.1 Schéma d'ensemble



Le siège est organisé autour de pfSense-HQ, qui interconnecte six segments (WAN, USERS, SRV, DMZ, ADMIN, DEMO). Chaque segment correspond à un réseau interne VirtualBox distinct et à une interface dédiée du pare-feu, donc aucun flux ne passe d'une zone à l'autre sans être filtré. Le site secondaire dispose de son propre pare-feu (pfSense-S2) et de son propre accès Internet. Il est relié au siège par un tunnel IPsec.

Les salariés distants se connectent par OpenVPN sur le WAN du siège.

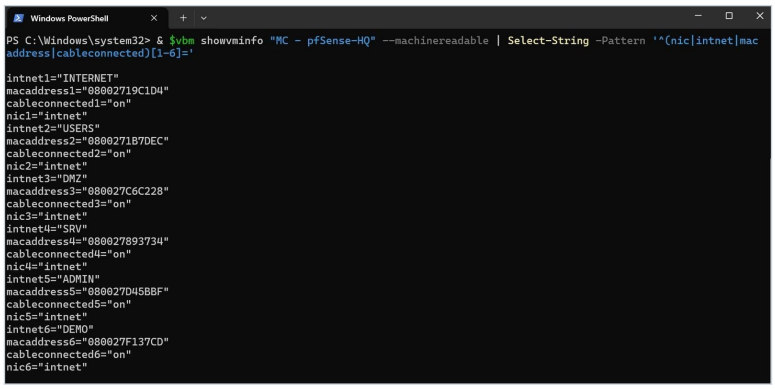
Les flux principaux de l'architecture sont décrits ci-dessous.

- **Le patient** arrive d'Internet sur 203.0.113.1:443 et il est redirigé vers le portail de la DMZ. Aucun autre port n'est exposé.
- **Le médecin** suit le même chemin, mais l'espace /medecin/ exige en plus un certificat client (mTLS).
- **Le salarié ou le commercial à distance** ouvre un tunnel OpenVPN sur le port de son profil (UDP 1194 à 1196) et n'accède ensuite qu'aux ressources de ce profil.
- **Le site secondaire** passe par un tunnel IPsec vers le siège, limité à l'annuaire.
- **Un poste du siège (USERS)** peut naviguer sur Internet et utiliser les applications internes, sans accès aux zones ADMIN, DMZ et DEMO.
- **L'administrateur** travaille uniquement depuis le bastion de la zone ADMIN pour accéder à l'interface de pfSense et aux serveurs.
- **La supervision** repose sur l'envoi des journaux de pfSense en syslog et sur les agents des machines, vers Wazuh.

2.2 Choix techniques

Composant	Rôle	Justification
pfSense CE 2.9.0	Pare-feu, routage, VPN	Filtrage à états, IPsec, OpenVPN et paquets de sécurité dans une seule solution libre, administrable en HTTPS
IPsec IKEv2	Liaison entre les sites	Standard du VPN site à site, avec une authentification mutuelle par certificats plutôt que par clé partagée
OpenVPN	Accès distant	Certificat et mot de passe LDAP, avec un sous-réseau de tunnel par profil pour filtrer selon l'identité
OpenLDAP et LAM	Annuaire central	Comptes et groupes uniques pour tous les services, gérés depuis LDAP Account Manager
PKI interne pfSense	Certificats	Une autorité unique (MediConnect-CA) pour IPsec, LDAPS, OpenVPN et les médecins
nginx	Portail (DMZ) et démo (DEMO)	Simule l'application et porte le HTTPS ainsi que la vérification des certificats des médecins
Suricata, pfBlockerNG, ntopng	Contrôle applicatif	Détection d'intrusion, réputation IP et filtrage DNS, identification des protocoles applicatifs
Wazuh 4.14	SIEM	Centralise les journaux de pfSense et des agents, avec des règles de détection personnalisées

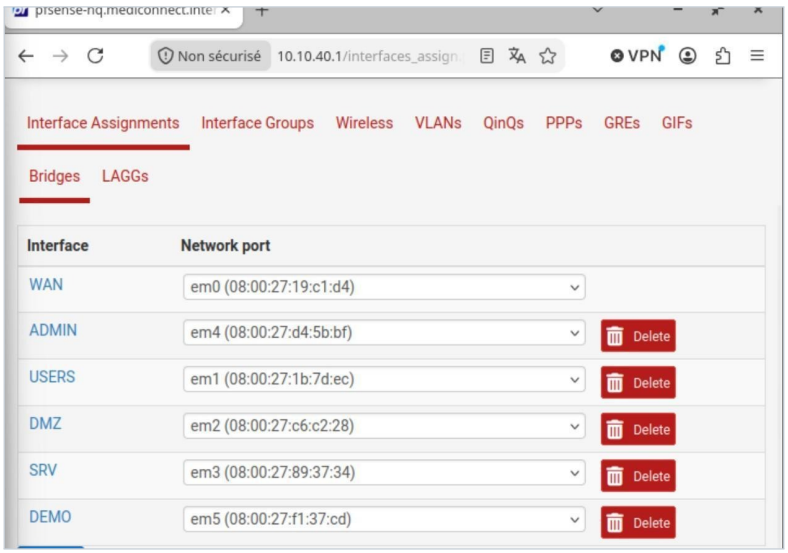
Chaque carte réseau de pfSense-HQ est reliée à un réseau interne VirtualBox distinct (INTERNET, USERS, DMZ, SRV, ADMIN, DEMO). Deux zones ne partagent donc jamais le même segment. La segmentation est physique dans la maquette, et pas seulement logique comme avec des VLAN. Tout échange entre zones traverse obligatoirement le pare-feu.



2.3 Plan d'adressage

Le siège utilise le bloc 10.10.0.0/16 (un /24 par zone), le site secondaire 10.20.0.0/16 et les tunnels OpenVPN 10.99.0.0/16. Ce découpage permet de résumer chaque site par un seul préfixe dans la phase 2 IPsec et de reconnaître l'origine d'un flux à son adresse. L'Internet simulé utilise la plage de documentation 203.0.113.0/24.

Zone	Interface	Réseau	Passerelle	Hôtes
WAN (Internet simulé)	em0	203.0.113.0/24	203.0.113.1	pfSense-S2 203.0.113.2, Kali 203.0.113.10
USERS	em1	10.10.10.0/24	10.10.10.1	client-users 10.10.10.10
DMZ	em2	10.10.30.0/24	10.10.30.1	dmz-web (nginx) 10.10.30.10
SRV	em3	10.10.20.0/24	10.10.20.1	mc-srv-ldap 10.10.20.10, mc-wazuh 10.10.20.20
ADMIN	em4	10.10.40.0/24	10.10.40.1	bastion admin 10.10.40.10
DEMO	em5	10.10.50.0/24	10.10.50.1	mc-demo 10.10.50.10
LAN site 2	pfSense-S2	10.20.10.0/24	10.20.10.1	client-s2
VPN support	ovpns1 (UDP 1194)	10.99.1.0/24	-	alice
VPN admins	ovpns2 (UDP 1195)	10.99.2.0/24	-	eva
VPN commerciaux	ovpns3 (UDP 1196)	10.99.3.0/24	-	farid



3 Zones de sécurité et niveaux de confiance

Chaque zone reçoit un niveau de confiance. Un flux n'est ouvert que d'une zone de confiance supérieure vers une zone inférieure, ou vers un service précis lorsqu'un besoin métier le justifie. Tout le reste est refusé par défaut.

Zone	Contenu	Confiance	Justification
Internet (WAN)	Patients, médecins, salariés nomades	Nulle	Aucune hypothèse sur l'émetteur. Seuls le portail (443) et OpenVPN (UDP 1194-1196) sont joignables
DMZ	Portail nginx	Faible	Exposée à Internet, donc considérée comme compromissible. Elle n'initie que LDAPS et l'agent Wazuh
DEMO	Copie de la plateforme, données fictives	Faible	Isolée de tous les réseaux privés, c'est la seule destination des commerciaux
VPN	Salariés authentifiés à distance	Moyenne	Identité vérifiée (certificat et LDAP), accès limité aux ressources du profil
USERS / LAN site 2	Postes des salariés	Moyenne	Postes internes mais exposés (navigation, messagerie), sans aucun accès à l'administration
SRV	Annuaire, SIEM	Élevée	Données sensibles. Les serveurs n'initient aucun flux vers les autres zones
ADMIN	Bastion d'administration	Maximale	Seule zone autorisée à administrer le pare-feu et les serveurs

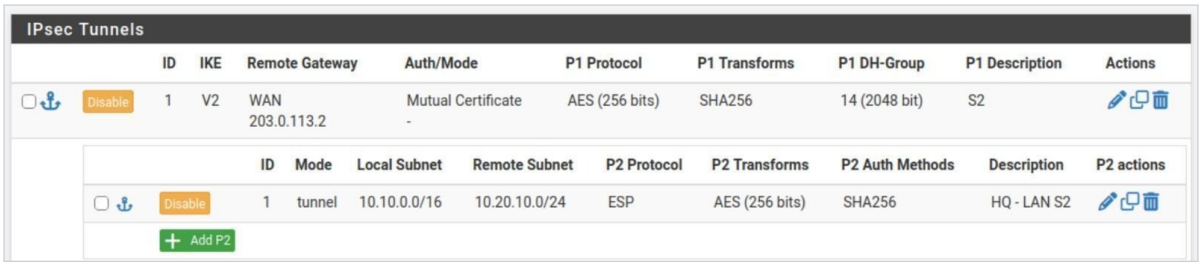
4 VPN et authentification

4.1 VPN site à site (IPsec)

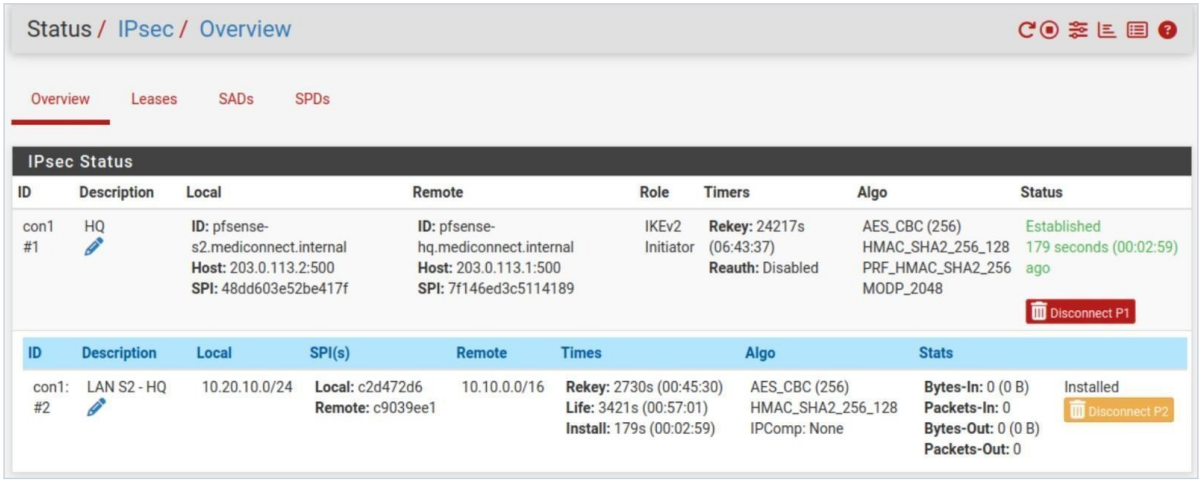
Le tunnel relie pfSense-S2 (203.0.113.2) à pfSense-HQ (203.0.113.1) en IKEv2. L'authentification est mutuelle par certificats (cert-hq et cert-s2, émis par la CA interne), ce qui évite une clé partagée.

- Phase 1 en AES-256 et SHA-256, avec le groupe DH 14 (2048 bits).
- Phase 2 (ESP) en AES-256 et SHA-256, entre 10.20.10.0/24 et 10.10.0.0/16.

IKEv2 a été préféré à IKEv1 pour sa négociation plus simple et plus robuste. L'authentification par certificats évite qu'une seule clé partagée, si elle fuyait, suffise à usurper un site. Elle permet aussi de révoquer un site sans toucher à l'autre.



Le tunnel ne donne pas accès à tout le siège. Les règles de l'interface IPsec (section 5.2) n'autorisent depuis le site secondaire que l'annuaire (10.10.20.10, LDAPS et ICMP de diagnostic). Tout autre flux est bloqué et journalisé. Depuis client-s2, l'annuaire répond au ping alors que la zone ADMIN reste injoignable.




```
xubuntu@client-s2:~$ ping -c 3 10.10.20.10
ping -c 3 10.10.40.10
PING 10.10.20.10 (10.10.20.10) 56(84) bytes of data.
64 bytes from 10.10.20.10: icmp_seq=1 ttl=62 time=6.42 ms
64 bytes from 10.10.20.10: icmp_seq=2 ttl=62 time=7.43 ms
64 bytes from 10.10.20.10: icmp_seq=3 ttl=62 time=7.58 ms

--- 10.10.20.10 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2003ms
rtt min/avg/max/mdev = 6.419/7.141/7.576/0.514 ms
PING 10.10.40.10 (10.10.40.10) 56(84) bytes of data.

--- 10.10.40.10 ping statistics ---
3 packets transmitted, 0 received, 100% packet loss, time 2052ms

xubuntu@client-s2:~$
```

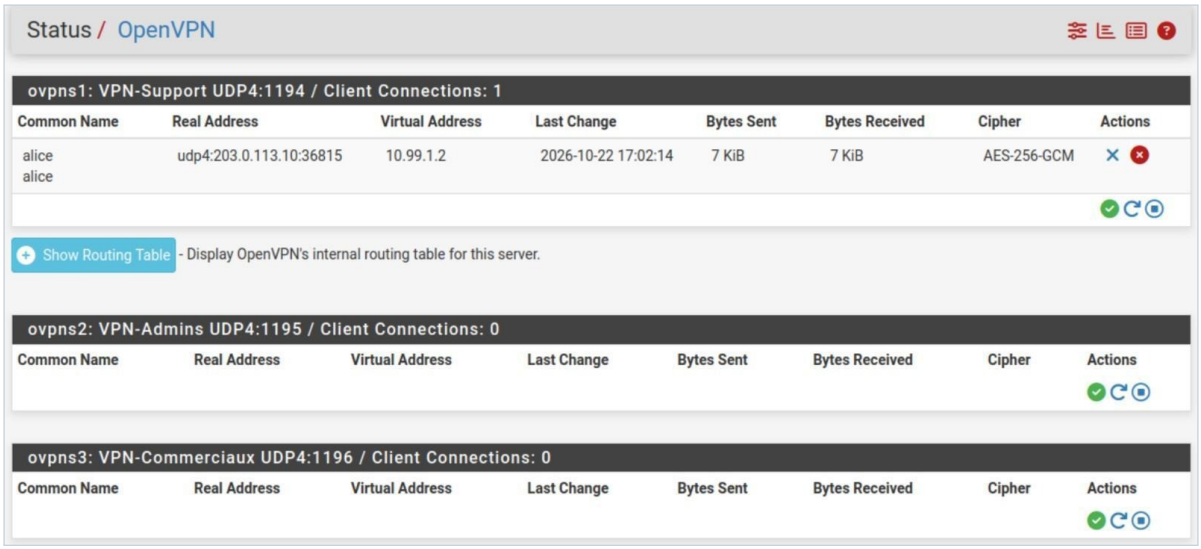
4.2 VPN d'accès distant (OpenVPN)

OpenVPN a été retenu pour l'accès distant car il fonctionne sur un seul port UDP, traverse sans difficulté les réseaux domestiques et publics (NAT), dispose de clients sur tous les systèmes et s'intègre à l'annuaire LDAP de pfSense.

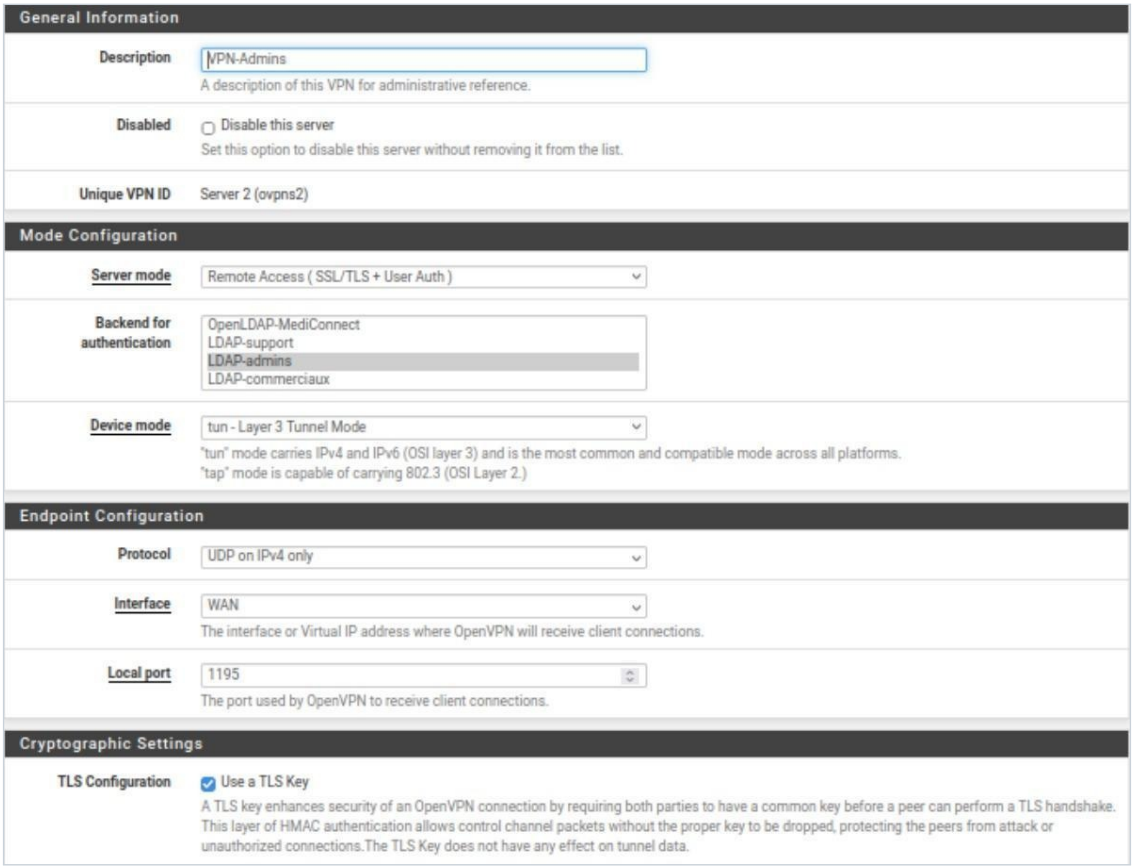
Une instance OpenVPN est créée par profil. Chaque instance possède son propre port et son propre sous-réseau de tunnel. L'adresse source d'un client suffit donc au pare-feu pour savoir à quel profil il appartient (section 5.3).

Profil (groupe LDAP)	Utilisateur de test	Port	Tunnel	Ressources autorisées
support	alice	UDP 1194	10.99.1.0/24	Portail (H_DMZ_WEB, HTTPS), qui simule les applications de support
admins	eva	UDP 1195	10.99.2.0/24	Zones ADMIN, SRV et DMZ (N_ADMIN_ACCES, TCP)
commerciaux	farid	UDP 1196	10.99.3.0/24	Zone DEMO uniquement (H_DEMO_WEB, HTTP/HTTPS)

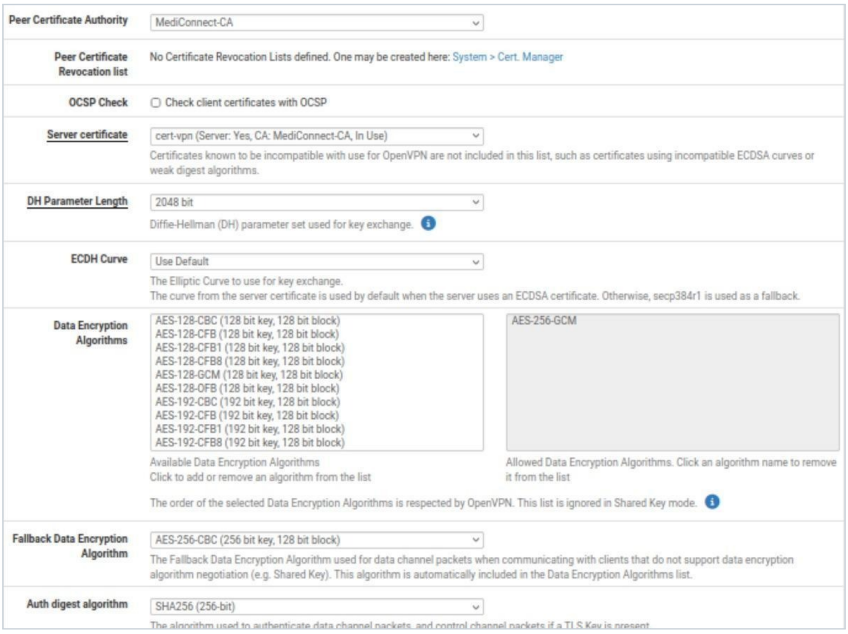
Les groupes compta, employes et it existent aussi dans l'annuaire. En production, ils recevraient chacun une instance sur le même modèle.



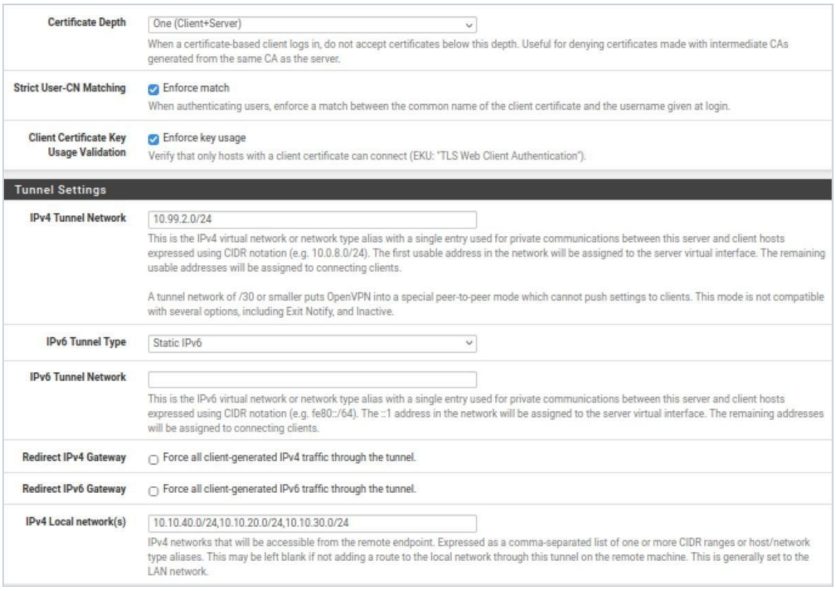
Les captures suivantes détaillent l'instance des administrateurs (VPN-Admins), les deux autres étant construites sur le même modèle. Le mode Remote Access (SSL/TLS + User Auth) impose à la fois un certificat client et un mot de passe, et le serveur d'authentification choisi est LDAP-admins, filtré sur le groupe admins. Un membre du groupe support ne peut donc pas ouvrir de session sur cette instance. L'instance écoute sur le WAN en UDP 1195 et utilise une clé TLS qui rejette, avant toute négociation, les paquets non signés.



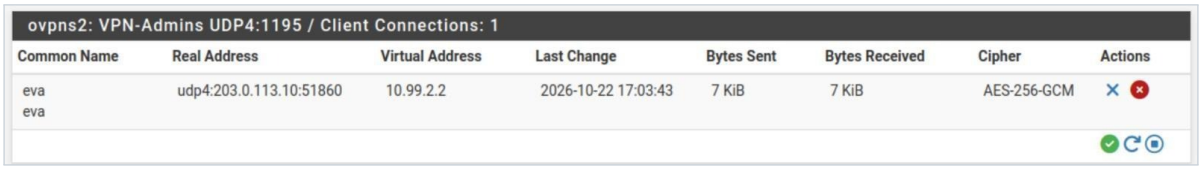
Le canal de contrôle est authentifié par la CA MediConnect-CA et le certificat serveur cert-vpn. Les données sont chiffrées en AES-256-GCM, avec SHA256 pour l'authentification et un échange Diffie-Hellman de 2048 bits.

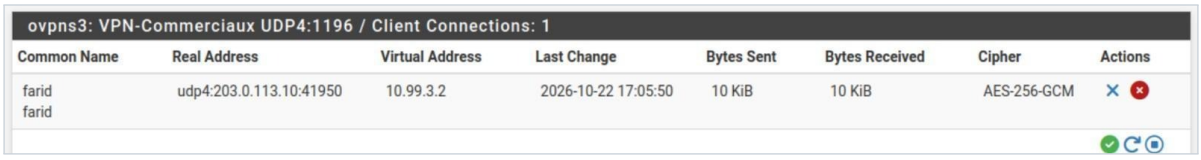


L'option Strict User-CN Matching exige que le CN du certificat soit identique à l'identifiant saisi, donc eva ne peut pas utiliser le certificat d'alice. Les clients reçoivent une adresse de 10.99.2.0/24 et seules les routes de 10.10.40.0/24, 10.10.20.0/24 et 10.10.30.0/24 leur sont poussées. La zone DEMO n'est même pas routée vers les administrateurs, et le pare-feu la bloque en plus. La compression est refusée et la passerelle par défaut du client n'est pas redirigée.



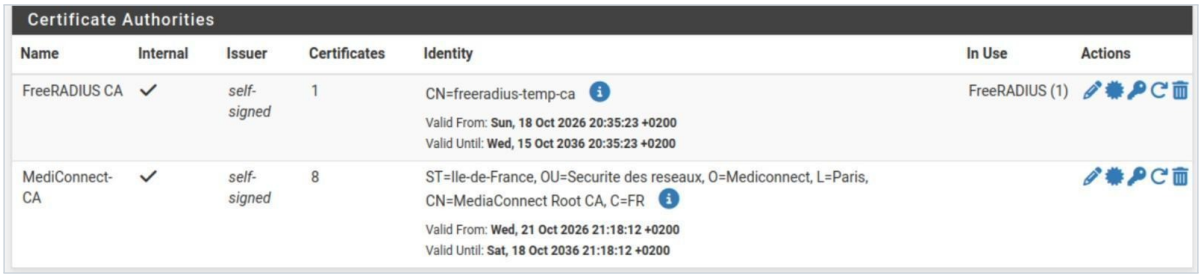
Les fichiers clients sont produits par le paquet openvpn-client-export. Côté pfSense, chaque utilisateur apparaît connecté sur l'instance de son profil, avec une adresse de son sous-réseau, comme le montrent les captures ci-dessous.

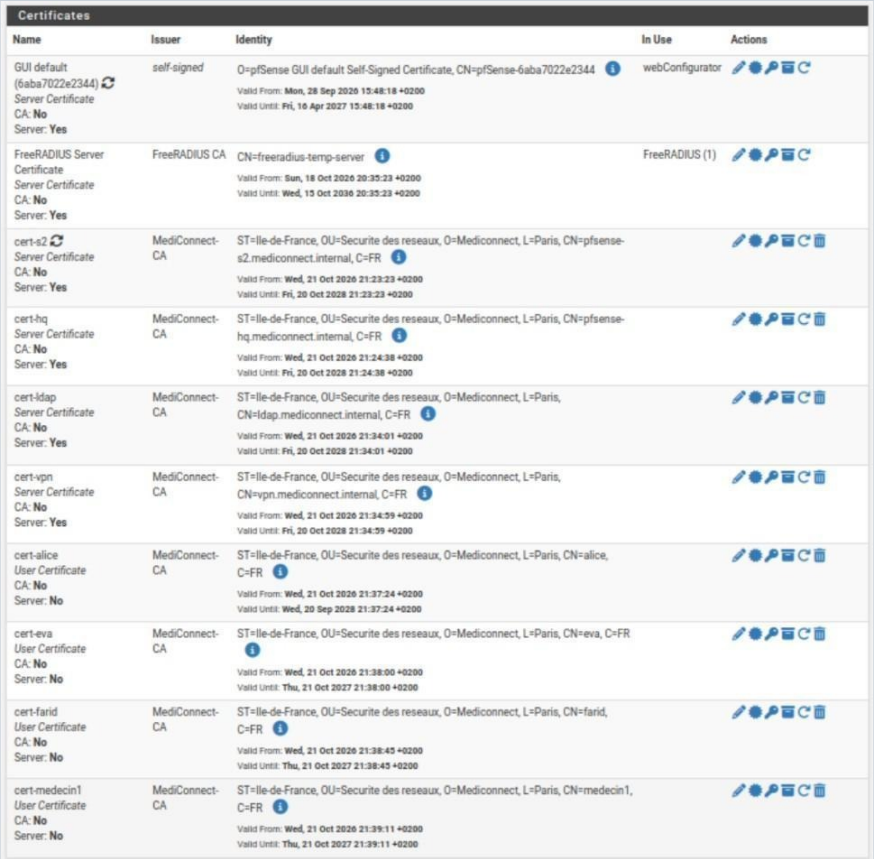




4.3 PKI

Une autorité de certification interne, MediConnect-CA (validité de dix ans), émet tous les certificats de l'infrastructure. Il s'agit des certificats serveur cert-hq et cert-s2 (IPsec), cert-vpn (OpenVPN) et cert-ldap (LDAPS), des certificats utilisateurs cert-alice, cert-eva et cert-farid (OpenVPN) et du certificat cert-medecin1 (accès médecin). Un seul point de confiance suffit ainsi à tous les services.





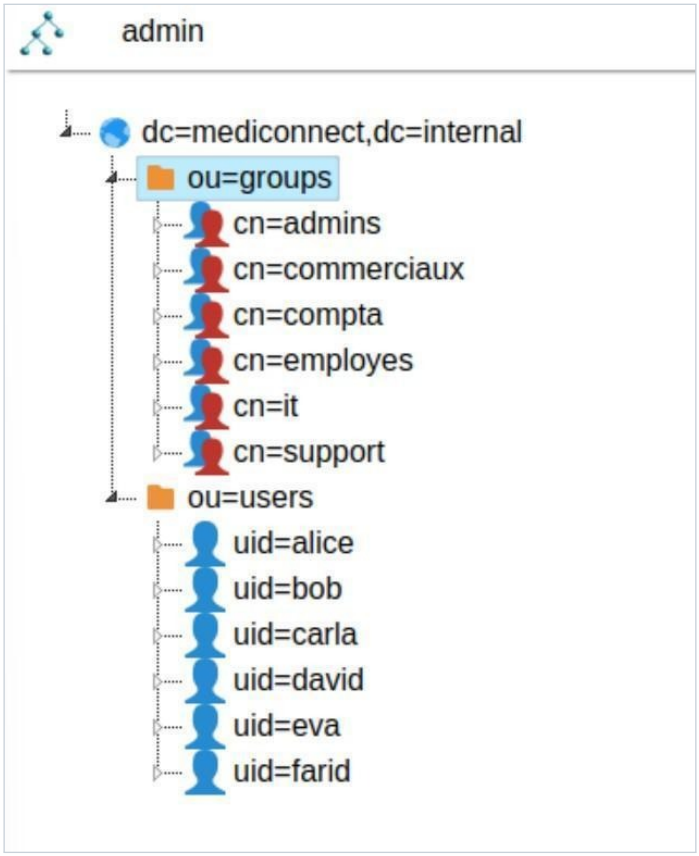
Certificates

Name	Issuer	Identity	In Use	Actions
GUI default (6aba7022e2344) *Server Certificate* CA: **No** Server: **Yes**	self-signed	O=pfSense GUI default Self-Signed Certificate, CN=pfSense-6aba7022e2344 Valid From: **Mon, 28 Sep 2026 15:48:18 +0200** Valid Until: **Fri, 16 Apr 2027 15:48:18 +0200**	webConfigurator	
FreeRADIUS Server Certificate *Server Certificate* CA: **No** Server: **Yes**	FreeRADIUS CA	CN=freeradius-temp-server Valid From: **Sun, 18 Oct 2026 20:35:23 +0200** Valid Until: **Wed, 15 Oct 2036 20:35:23 +0200**	FreeRADIUS (1)	
cert-s2 *Server Certificate* CA: **No** Server: **Yes**	MediConnect-CA	ST=Ile-de-France, OU=Securite des reseaux, O=Mediconnect, L=Paris, CN=pfsense-s2.mediconnect.internal, C=FR Valid From: **Wed, 21 Oct 2026 21:23:23 +0200** Valid Until: **Fri, 20 Oct 2028 21:23:23 +0200**		
cert-hq *Server Certificate* CA: **No** Server: **Yes**	MediConnect-CA	ST=Ile-de-France, OU=Securite des reseaux, O=Mediconnect, L=Paris, CN=pfsense-hq.mediconnect.internal, C=FR Valid From: **Wed, 21 Oct 2026 21:24:38 +0200** Valid Until: **Fri, 20 Oct 2028 21:24:38 +0200**		
cert-ldap *Server Certificate* CA: **No** Server: **Yes**	MediConnect-CA	ST=Ile-de-France, OU=Securite des reseaux, O=Mediconnect, L=Paris, CN=ldap.mediconnect.internal, C=FR Valid From: **Wed, 21 Oct 2026 21:34:01 +0200** Valid Until: **Fri, 20 Oct 2028 21:34:01 +0200**		
cert-vpn *Server Certificate* CA: **No** Server: **Yes**	MediConnect-CA	ST=Ile-de-France, OU=Securite des reseaux, O=Mediconnect, L=Paris, CN=vpn.mediconnect.internal, C=FR Valid From: **Wed, 21 Oct 2026 21:34:59 +0200** Valid Until: **Fri, 20 Oct 2028 21:34:59 +0200**		
cert-alice *User Certificate* CA: **No** Server: **No**	MediConnect-CA	ST=Ile-de-France, OU=Securite des reseaux, O=Mediconnect, L=Paris, CN=alice, C=FR Valid From: **Wed, 21 Oct 2026 21:37:24 +0200** Valid Until: **Wed, 20 Sep 2028 21:37:24 +0200**		
cert-eva *User Certificate* CA: **No** Server: **No**	MediConnect-CA	ST=Ile-de-France, OU=Securite des reseaux, O=Mediconnect, L=Paris, CN=eva, C=FR Valid From: **Wed, 21 Oct 2026 21:38:00 +0200** Valid Until: **Thu, 21 Oct 2027 21:38:00 +0200**		
cert-farid *User Certificate* CA: **No** Server: **No**	MediConnect-CA	ST=Ile-de-France, OU=Securite des reseaux, O=Mediconnect, L=Paris, CN=farid, C=FR Valid From: **Wed, 21 Oct 2026 21:38:45 +0200** Valid Until: **Thu, 21 Oct 2027 21:38:45 +0200**		
cert-medecin1 *User Certificate* CA: **No** Server: **No**	MediConnect-CA	ST=Ile-de-France, OU=Securite des reseaux, O=Mediconnect, L=Paris, CN=medecin1, C=FR Valid From: **Wed, 21 Oct 2026 21:39:11 +0200** Valid Until: **Thu, 21 Oct 2027 21:39:11 +0200**		

4.4 Authentification

4.4.1 Annuaire OpenLDAP

L'annuaire dc=mediconnect,dc=internal est hébergé sur mc-srv-ldap (zone SRV). Il contient six comptes (ou=users) et six groupes (ou=groups) calqués sur les populations du sujet (support, compta, employes, it, admins et commerciaux). L'overlay memberOf ajoute à chaque compte la liste de ses groupes, que pfSense utilise comme filtre. L'administration se fait avec LDAP Account Manager.




```
mc-srv-ldap@mc-srv-ldap:~$ ldapsearch -x -LLL -b ou=groups,dc=mediconnect,dc=internal "
(objectClass=groupOfNames)" cn member
dn: cn=support,ou=groups,dc=mediconnect,dc=internal
cn: support
member: uid=alice,ou=users,dc=mediconnect,dc=internal

dn: cn=compta,ou=groups,dc=mediconnect,dc=internal
cn: compta
member: uid=bob,ou=users,dc=mediconnect,dc=internal

dn: cn=employes,ou=groups,dc=mediconnect,dc=internal
cn: employes
member: uid=carla,ou=users,dc=mediconnect,dc=internal

dn: cn=it,ou=groups,dc=mediconnect,dc=internal
cn: it
member: uid=david,ou=users,dc=mediconnect,dc=internal

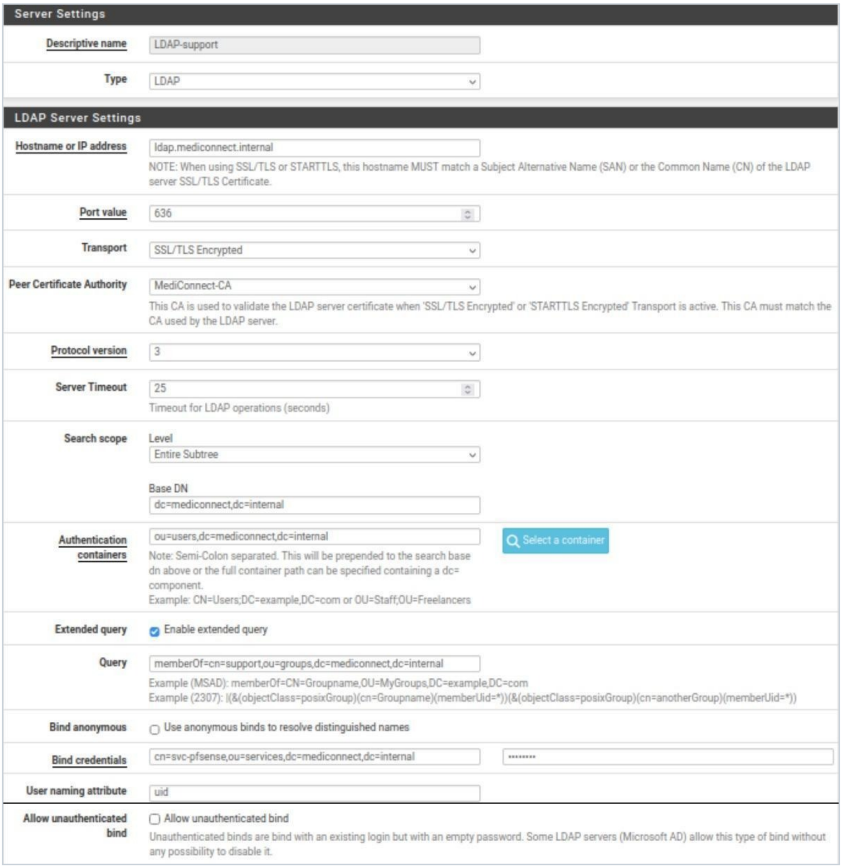
dn: cn=admins,ou=groups,dc=mediconnect,dc=internal
cn: admins
member: uid=eva,ou=users,dc=mediconnect,dc=internal

dn: cn=commerciaux,ou=groups,dc=mediconnect,dc=internal
cn: commerciaux
member: uid=farid,ou=users,dc=mediconnect,dc=internal

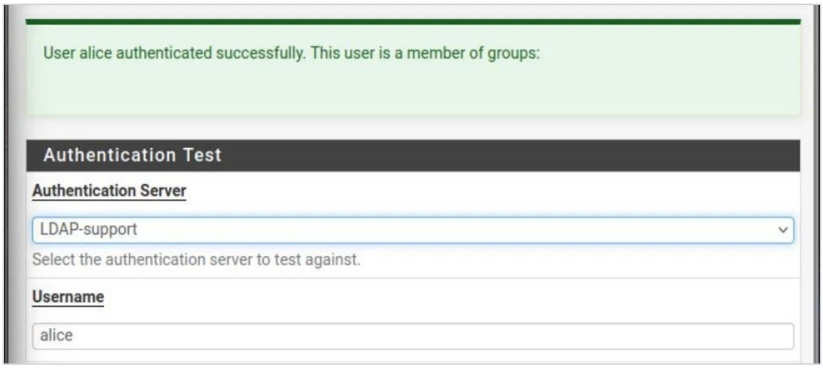
mc-srv-ldap@mc-srv-ldap:~$
```

4.4.2 LDAPS et compte de service

pfSense interroge l'annuaire en LDAPS sur le serveur ldap.mediconnect.internal, port 636, avec le transport SSL/TLS Encrypted. Le certificat cert-ldap du serveur est vérifié par rapport à MediConnect-CA. Les mots de passe ne circulent donc jamais en clair et le serveur est authentifié. La requête étendue memberOf=cn=support,ou=groups,dc=mediconnect,dc=internal limite ce serveur d'authentification aux membres du groupe support. LDAP-admins et LDAP-commerciaux suivent le même modèle avec leur groupe. pfSense se connecte avec le compte de service cn=svc-pfsense,ou=services, en lecture seule, et non avec l'administrateur de l'annuaire, ce qui limite l'impact d'une fuite de ce mot de passe. Les connexions anonymes et les connexions sans mot de passe sont refusées.



Le test du serveur d'authentification confirme le filtre. Alice est acceptée par LDAP-support et refusée par LDAP-admins.





4.4.3 Authentification multifacteur

Le sujet présente la MFA comme une option. Dans la maquette, l'accès distant des salariés combine déjà deux facteurs de nature différente, un certificat (possession) et un mot de passe LDAP (connaissance). Un code TOTP n'a pas été ajouté et reste une amélioration identifiée en section 10.

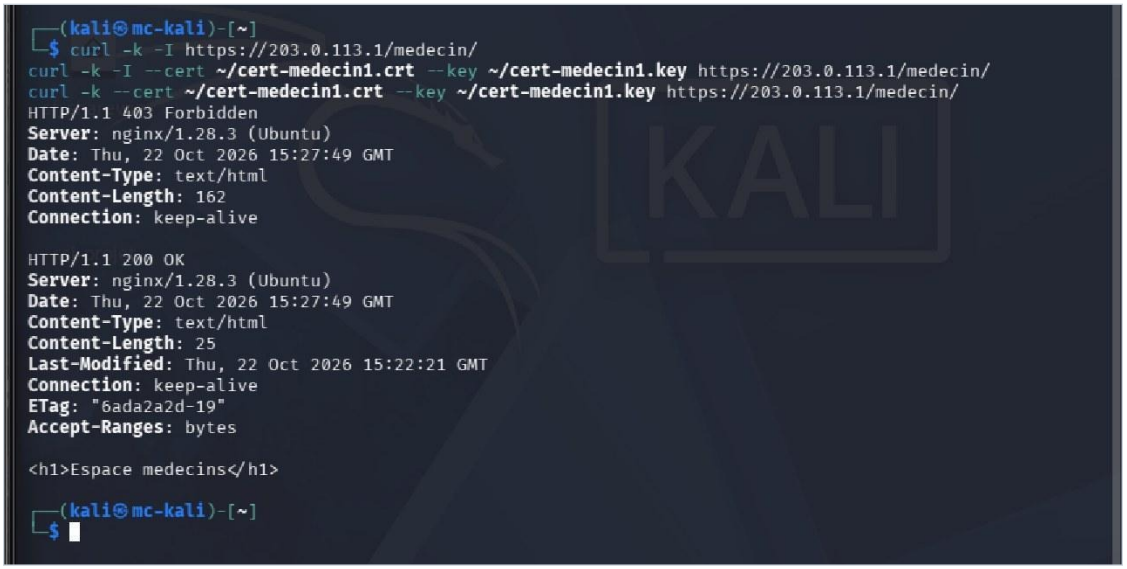
4.4.4 Accès des médecins (mTLS)

Les médecins utilisent le même point d'entrée que les patients (203.0.113.1:443), mais le chemin /medecin/ exige un certificat client signé par MediConnect-CA. nginx charge la CA (ssl_client_certificate), demande le certificat (ssl_verify_client optional) et renvoie une erreur 403 sur /medecin/ si la vérification échoue. Les médecins n'atteignent ainsi que la DMZ, en HTTPS, sans aucun accès réseau aux serveurs internes.

Le mode optional, plutôt que on, laisse le portail public accessible aux patients sans certificat, et seul l'espace /medecin/ impose la vérification. La configuration retenue est présentée ci-dessous.

```
server {
    listen 443 ssl;
    server_name portail.mediconnect.internal;
    ssl_certificate         /etc/nginx/ssl/portail.crt;
    ssl_certificate_key     /etc/nginx/ssl/portail.key;
    ssl_protocols           TLSv1.2 TLSv1.3;
    ssl_client_certificate  /etc/nginx/ssl/MediConnect-CA.crt;
    ssl_verify_client       optional;
    root /var/www/mediconnect;
    index index.html;
    location /medecin/ {
        if ($ssl_client_verify != SUCCESS) { return 403; }
    }
}
```

Sans certificat, /medecin/ renvoie 403. Avec cert-medecin1, il renvoie 200 et l'espace médecins s'affiche.


┌──(kali㉿mc-kali)-[~]
└─$ curl -k -I https://203.0.113.1/medecin/
curl -k -I --cert ~/cert-medecin1.crt --key ~/cert-medecin1.key https://203.0.113.1/medecin/
curl -k --cert ~/cert-medecin1.crt --key ~/cert-medecin1.key https://203.0.113.1/medecin/
HTTP/1.1 403 Forbidden
Server: nginx/1.28.3 (Ubuntu)
Date: Thu, 22 Oct 2026 15:27:49 GMT
Content-Type: text/html
Content-Length: 162
Connection: keep-alive
HTTP/1.1 200 OK
Server: nginx/1.28.3 (Ubuntu)
Date: Thu, 22 Oct 2026 15:27:49 GMT
Content-Type: text/html
Content-Length: 25
Last-Modified: Thu, 22 Oct 2026 15:22:21 GMT
Connection: keep-alive
ETag: "6ada2a2d-19"
Accept-Ranges: bytes
<h1>Espace medecins</h1>
┌──(kali㉿mc-kali)-[~]
└─$

5 Politique de filtrage

5.1 Principes et alias

- Le refus est appliqué par défaut et chaque zone se termine par une règle de blocage explicite et journalisée.
- Les règles sont appliquées à l'entrée de chaque interface et la première règle correspondante s'applique.
- Le pare-feu lui-même n'est joignable que depuis ADMIN. Les autres zones n'y accèdent que pour le DNS et le NTP.
- Des alias sont utilisés pour la lisibilité, pour les réseaux (NET_*), les hôtes (H_*), les groupes de zones interdites (GRP_BLOCK_*) et les ports (P_*).
- pfBlockerNG place en tête des interfaces une règle qui bloque les adresses IP de mauvaise réputation (pfB_PRI1_v4).

Deux choix structurent les règles. D'une part, les blocages vers les zones internes sont placés avant les autorisations larges. Dans USERS, la règle qui interdit ADMIN, DMZ et DEMO précède celle qui ouvre le web, qui ne vise elle-même que les adresses non privées. D'autre part, les zones interdites sont regroupées dans des alias (GRP_BLOCK_*), ainsi l'ajout d'une zone ne demande qu'une modification d'alias, sans retoucher chaque interface.

IP Ports URLs All

Firewall Aliases IP

Name	Type	Values	Description	Actions
GRP_BLOCK_DMZ	Network(s)	NET_USER, NET_ADMIN, NET_DEMO, NET_SRV	Règle D3	
GRP_BLOCK_SRV	Network(s)	NET_USER, NET_ADMIN, NET_DMZ, NET_DEMO	Règle S1	
GRP_BLOCK_USERS	Network(s)	NET_ADMIN, NET_DMZ, NET_DEMO	Règle U2 Matrice	
H_ADMIN_ACCES	Host(s)	10.10.40.0, 10.10.40.1, 10.10.40.2, 10.10.40.3, 10.10.40.4, 10.10.40.5, 10.10.40.6, 10.10.40.7, 10.10.40.8, 10.10.40.9, 10.10.40.10, 10.10.40.11, 10.10.40.12, 10.10.40.13, 10.10.40.14, 10.10.40.15, 10.10.40.16, 10.10.40.17, 10.10.40.18, 10.10.40.19…	Zones accessibles au profil admins	
H_ADMIN_BASTION	Host(s)	10.10.40.10	Poste d'administration	
H_DEMO_WEB	Host(s)	10.10.50.10	Portail de démo	
H_DMZ_WEB	Host(s)	10.10.30.10	Reverse proxy / portail	
H_SRV_LDAP	Host(s)	10.10.20.10	OpenLDAP	
H_UBUNTU_REPOS	Host(s)	archive.ubuntu.com, security.ubuntu.com		
H_WAZUH	Host(s)	10.10.20.20	SIEM / XDR	
NET_ADMIN	Network(s)	10.10.40.0/24	Zone Admin	
NET_DEMO	Network(s)	10.10.50.0/24	Zone démo	
NET_DMZ	Network(s)	10.10.30.0/24	DMZ	
NET_PRIVATE	Network(s)	10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16	Réseaux privés	
NET_S2	Network(s)	10.20.10.0/24	LAN site 2	
NET_SRV	Network(s)	10.10.20.0/24	Serveurs internes	

Firewall Aliases Ports

Name	Type	Values	Description	Actions
P_DNS	Port(s)	53	Résolution des noms	
P_HTTPS	Port(s)	443	Portail, GUI	
P_LDAPS	Port(s)	636	Annuaire chiffré	
P_SSH	Port(s)	22	Administration	
P_SYSLOG	Port(s)	514	Logs des pare-feux	
P_WAZUH_AGENT	Port(s)	1514, 1515	Agents Wazuh ver le manager	
P_WAZUH_API	Port(s)	55000	API Wazuh	
P_WEB	Port(s)	80, 443	80 et 443	

5.2 Règles de filtrage par interface

Les captures ci-dessous sont celles des règles réellement appliquées sur pfSense-HQ, interface par interface.

WAN. Seuls deux flux entrent depuis Internet. Le premier est TCP 443 vers le portail (H_DMZ_WEB), associé à la redirection NAT de WAN address:443. Le second est UDP 1194 à 1196 vers WAN address pour les trois instances OpenVPN. Les flux IKE et ESP du tunnel IPsec sont autorisés par les règles que pfSense ajoute automatiquement pour la passerelle distante. Tout le reste est rejeté par le refus par défaut, qui est journalisé.

Firewall / Rules / WAN

Floating WAN ADMIN USERS DMZ SRV DEMO VPN_SUPPORT VPN_ADMINS VPN_COMMERCIAUX IPsec OpenVPN

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
	0/69 KiB	IPv4 TCP	*	*	H_DMZ_WEB	443 (HTTPS)	*	none		NAT portail MediConnect	
	1/1.20 MiB	IPv4 UDP	*	*	WAN address	1194 - 1196	*	none		Autorise OpenVPN (3 profils) vers WAN	

Add Add Delete Toggle Copy Save Separator

Firewall / NAT / Port Forward

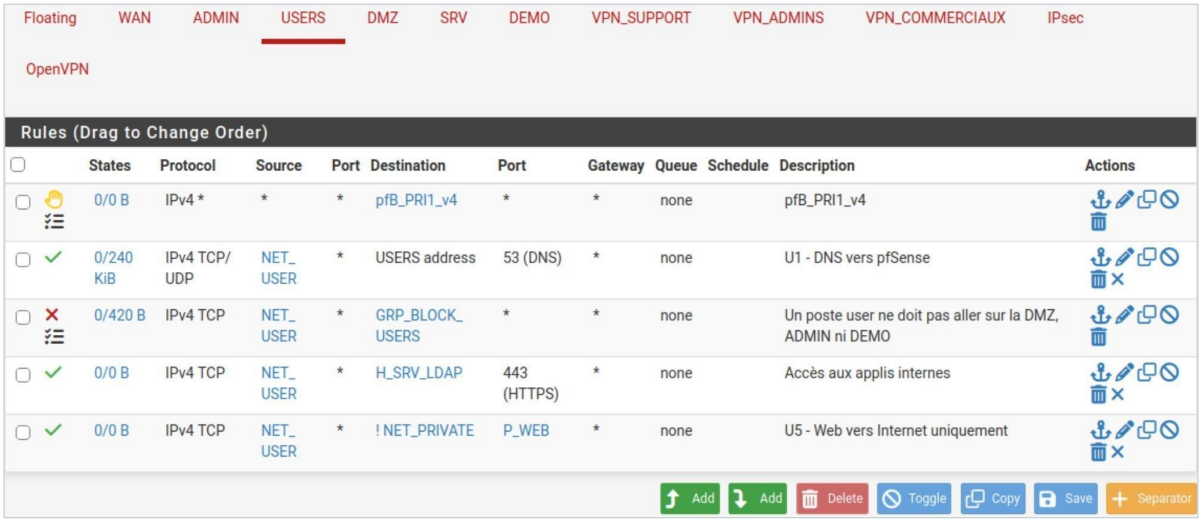
Port Forward 1:1 Outbound NPt

Rules

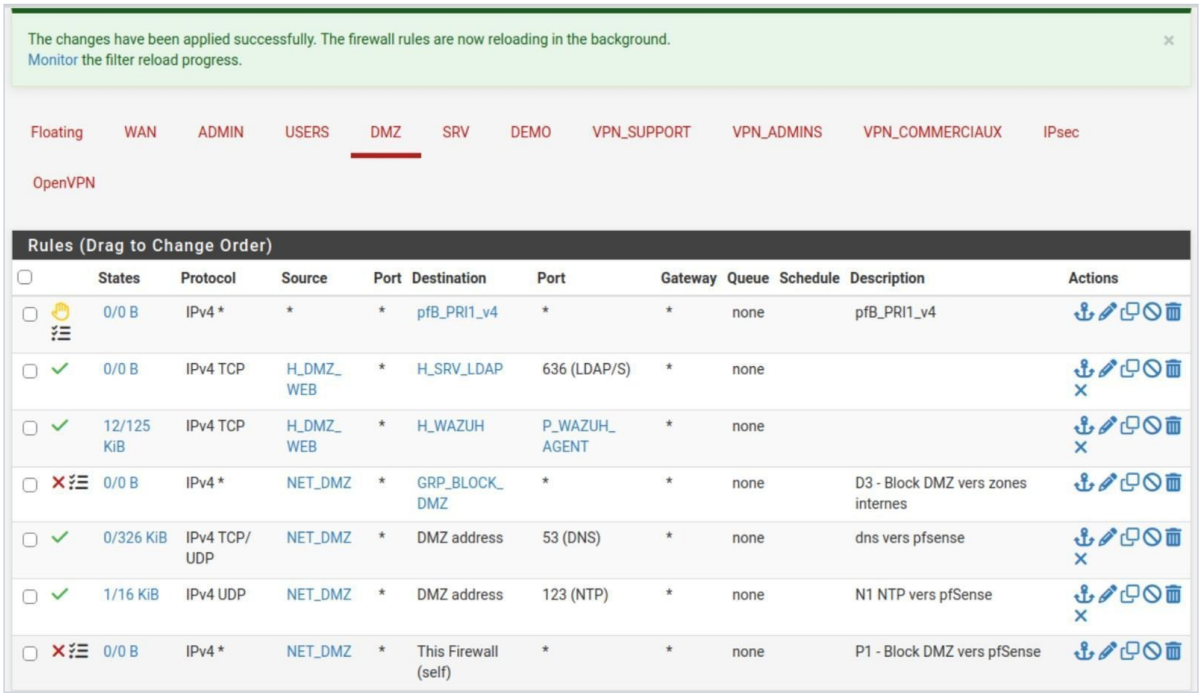
	Interface	Protocol	Source Address	Source Ports	Dest. Address	Dest. Ports	NAT IP	NAT Ports	Description	Actions
	WAN	TCP	*	*	WAN address	443 (HTTPS)	H_DMZ_WEB	443 (HTTPS)	portail MediConnect	

Add Add Delete Toggle Save Separator

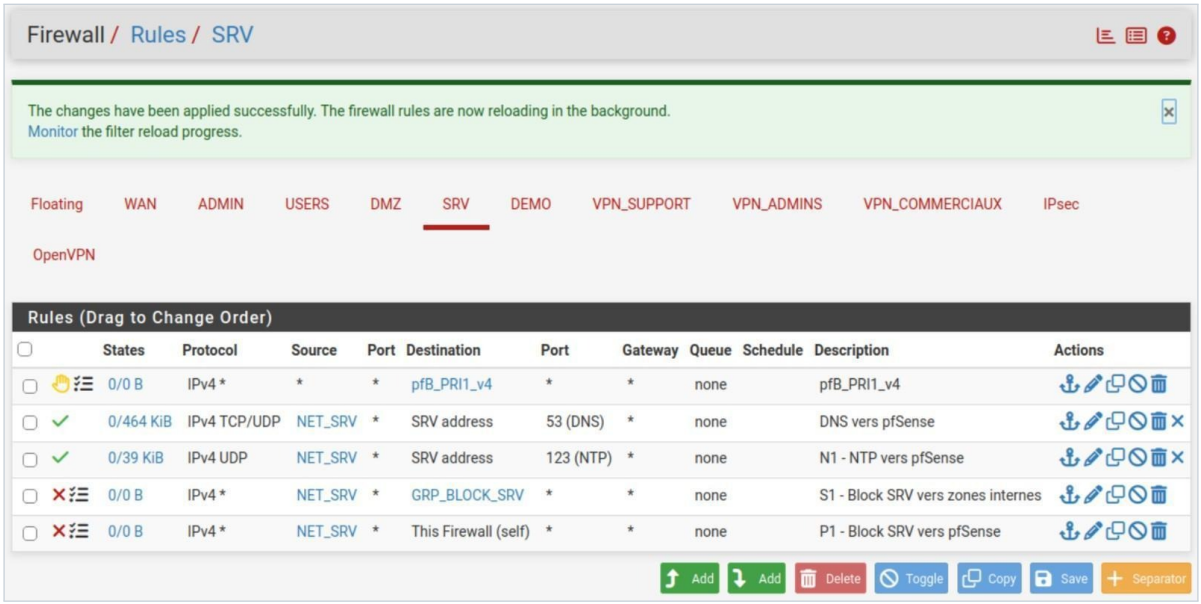
USERS. Les postes résolvent les noms par pfSense (TCP/UDP 53), n'ont aucun accès à la DMZ, à ADMIN ni à DEMO (GRP_BLOCK_USERS, bloqué et journalisé), accèdent aux applications internes en HTTPS (H_SRV_LDAP:443) et naviguent sur le web uniquement vers des adresses publiques (! NET_PRIVATE, P_WEB).



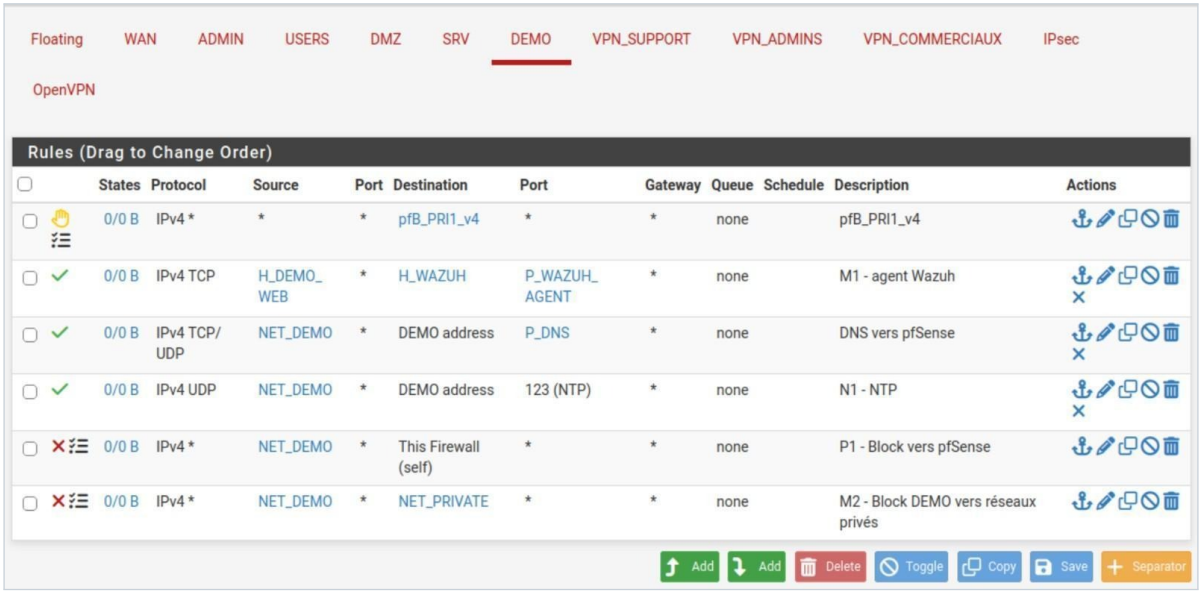
DMZ. Le portail n'initie que LDAPS vers l'annuaire (H_SRV_LDAP:636) et la connexion de son agent Wazuh (H_WAZUH, P_WAZUH_AGENT). Les autres zones internes (D3) et le pare-feu lui-même (P1) sont bloqués. Seuls le DNS et le NTP de pfSense restent permis.



SRV. Les serveurs n'initient aucun flux vers les autres zones (S1) ni vers le pare-feu (P1), en dehors du DNS et du NTP.



DEMO. L'environnement de démonstration ne peut joindre que Wazuh pour son agent (M1). Tous les réseaux privés (M2) et le pare-feu (P1) lui sont interdits, ce qui assure la séparation entre production et démonstration.



ADMIN. La zone d'administration dispose de la règle anti-blocage, du DNS et du NTP vers pfSense (A1, A2), de ntopng (A3), puis du SSH, du web et du ping vers ADMIN, SRV et DMZ (A4 à A6, alias N_ADMIN_ACCES). La règle A7 bloque et journalise tout le reste (section 7).

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
✓	1/4.44 MiB	*	*	*	ADMIN Address	443 80	*	*		Anti-Lockout Rule	⚙
✓	0/0 B	IPv4 TCP/ UDP	NET_ ADMIN	*	ADMIN address	P_DNS	*	none		A1 - DNS vers pfSense	
✓	0/0 B	IPv4 UDP	NET_ ADMIN	*	ADMIN address	123 (NTP)	*	none		A2 - NTP vers pfSense	
✓	0/0 B	IPv4 TCP	NET_ ADMIN	*	ADMIN address	3000 (HBCI)	*	none		A3 - ntopng	
✓	0/0 B	IPv4 TCP	NET_ ADMIN	*	N_ADMIN_ ACCES	P_SSH	*	none		A4 - SSH d'administration	
✓	0/0 B	IPv4 TCP	NET_ ADMIN	*	N_ADMIN_ ACCES	P_WEB	*	none		A5 - Interfaces web (LAM, Wazuh, nginx)	
✓	0/0 B	IPv4 ICMP any	NET_ ADMIN	*	N_ADMIN_ ACCES	*	*	none		A6 - Ping de diagnostic	
✗	0/0 B	IPv4 *	*	*	*	*	*	none		A7 - Bloc tout le reste (log)	

IPsec. Le site secondaire (10.20.10.0/24) n'atteint que l'annuaire 10.10.20.10, en LDAPS et en ping, et le reste est bloqué.

Firewall / Rules / IPsec

Floating WAN ADMIN USERS DMZ SRV DEMO IPsec

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
✓	0/1 KiB	IPv4 ICMP echoreq	10.20.10.0/24	*	10.10.20.10	*	*	none			
✓	0/0 B	IPv4 TCP	10.20.10.0/24	*	10.10.20.10	636 (LDAP/S)	*	none			
✗	0/756 B	IPv4 *	10.20.10.0/24	*	*	*	*	none			

Add Add Delete Toggle Copy Save Separator

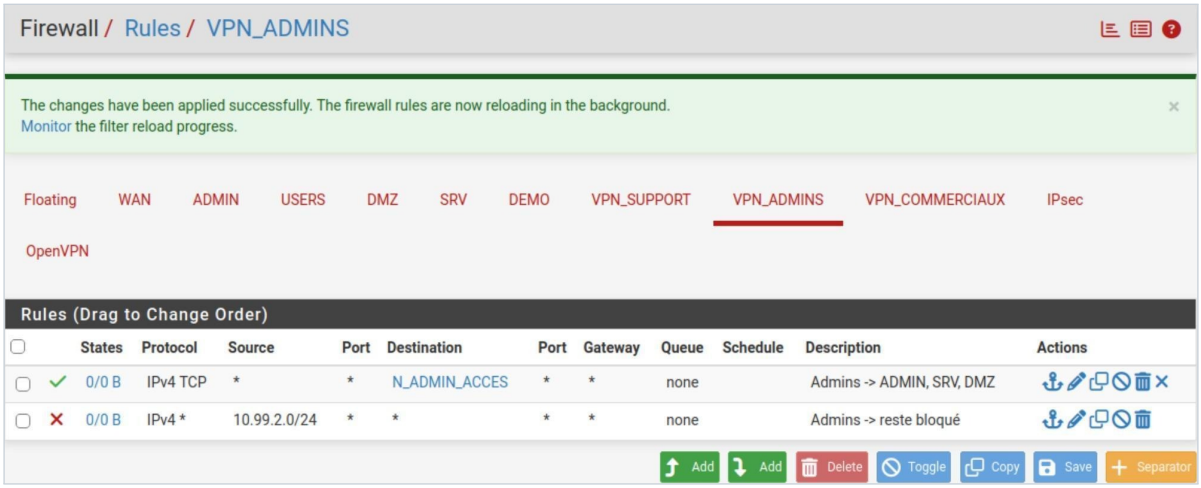
VPN. Chaque interface OpenVPN autorise les ressources de son profil puis bloque tout le reste depuis son sous-réseau de tunnel. Le support (10.99.1.0/24) n'atteint que le portail en HTTPS, les administrateurs N_ADMIN_ACCES en TCP et les commerciaux H_DEMO_WEB en HTTP/HTTPS.

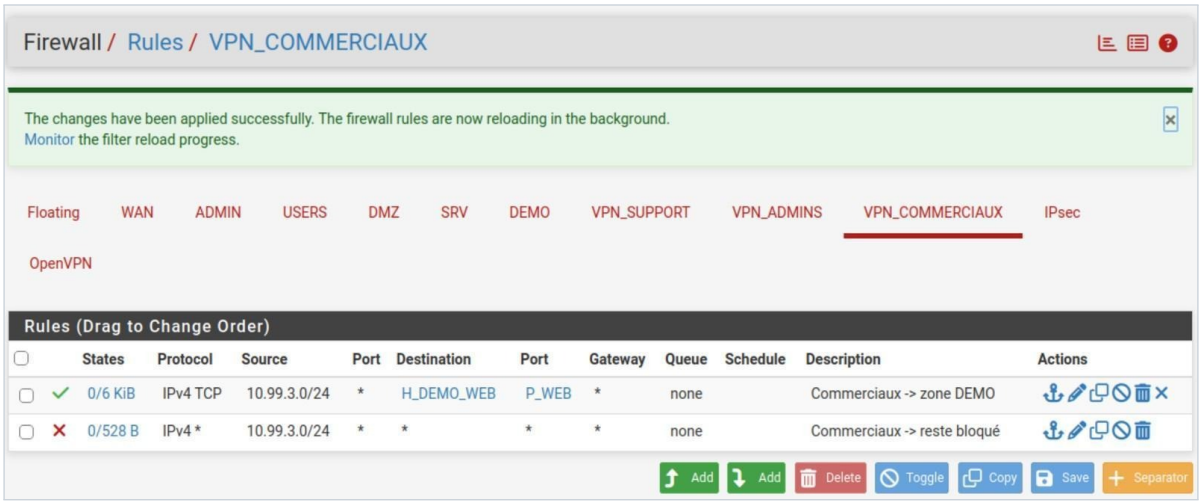
Floating WAN ADMIN USERS DMZ SRV DEMO VPN_SUPPORT VPN_ADMINS

VPN_COMMERCIAUX IPsec OpenVPN

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule
✓	0/0 B	IPv4 TCP	10.99.1.0/24	*	H_DMZ_WEB	443 (HTTPS)	*	none	
✗	0/0 B	IPv4 *	10.99.1.0/24	*	*	*	*	none	





5.3 Règles basées sur l'identité

L'identité de l'utilisateur détermine ses droits de bout en bout. Son groupe LDAP fixe l'instance OpenVPN sur laquelle il peut s'authentifier, l'instance lui attribue une adresse dans le sous-réseau du profil, et les règles de l'interface VPN correspondante n'autorisent que les ressources de ce profil. Une même machine (Kali) a été utilisée successivement avec les trois identités.

Profil	Flux autorisé	Résultat	Flux interdit	Résultat
alice (support)	Portail 10.10.30.10:443	200 OK	SRV 10.10.20.10	100 % de perte
eva (admins)	SRV 10.10.20.10:22	open	DEMO 10.10.50.10:443	timeout
farid (commerciaux)	DEMO 10.10.50.10:443	open	SRV 10.10.20.10	100 % de perte

Pour eva, la connexion se fait sur 203.0.113.1:1195 et l'adresse 10.99.2.2 est attribuée sur tun0. La route vers DEMO, que le serveur ne pousse pas, est ajoutée à la main pour forcer le paquet dans le tunnel. C'est alors la règle de blocage de VPN_ADMINS qui l'arrête, tandis que le SSH vers SRV passe.

```
Enter Auth Username: eva
Enter Auth Password: ••••••••
2026-10-22 21:04:02 TCP/UDP: Preserving recently used remote address: [AF_INET]203.0.113.1:1195
2026-10-22 21:04:02 UDPv4 link local: (not bound)
2026-10-22 21:04:02 UDPv4 link remote: [AF_INET]203.0.113.1:1195
2026-10-22 21:04:02 WARNING: this configuration may cache passwords in memory -- use the auth-nocache
option to prevent this
2026-10-22 21:04:02 [vpn.mediconnect.internal] Peer Connection Initiated with [AF_INET]203.0.113.1:119
5
2026-10-22 21:04:04 TUN/TAP device tun0 opened
2026-10-22 21:04:04 tun/tap device [tun0] opened
2026-10-22 21:04:04 net_iface_mtu_set: mtu 1500 for tun0
2026-10-22 21:04:04 net_iface_up: set tun0 up
2026-10-22 21:04:04 net_addr_v4_add: 10.99.2.2/24 dev tun0
2026-10-22 21:04:04 Initialization Sequence Completed
```

```
┌──(kali㉿mc-kali)-[~]
└─$ ip -br a | grep 10.99
tun0             UNKNOWN        10.99.2.2/24 fe80::8ab7:bc1c:d8b5:d91a/64

┌──(kali㉿mc-kali)-[~]
└─$ sudo ip route replace 10.10.20.10/32 dev tun0
sudo ip route replace 10.10.50.10/32 dev tun0
nc -zv -w 3 10.10.20.10 22
nc -zv -w 3 10.10.50.10 443
[sudo] Mot de passe de kali :
10.10.20.10: inverse host lookup failed: Host name lookup failure
(UNKNOWN) [10.10.20.10] 22 (ssh) open
10.10.50.10: inverse host lookup failed: Host name lookup failure
(UNKNOWN) [10.10.50.10] 443 (https) : Connection timed out
```

Les tests d'alice et de farid suivent la même méthode. La ressource de leur profil répond et la zone SRV reste injoignable.

```
kali@mc-kali: ~
Session  Actions  Éditer  Vue  Aide
kali@mc-kali: ~   kali@mc-kali: ~

┌──(kali㉿mc-kali)-[~]
└─$ ip -br a show tun0
ping -c 3 10.10.20.10
curl -k -I --max-time 8 https://10.10.30.10
sudo ip route replace 10.10.10.1/32 dev tun0
ping -c 3 -W 2 10.10.10.1
tun0             UNKNOWN        10.99.1.2/24 fe80::2923:a27e:e3f5:aabe/64
PING 10.10.20.10 (10.10.20.10) 56(84) bytes of data.

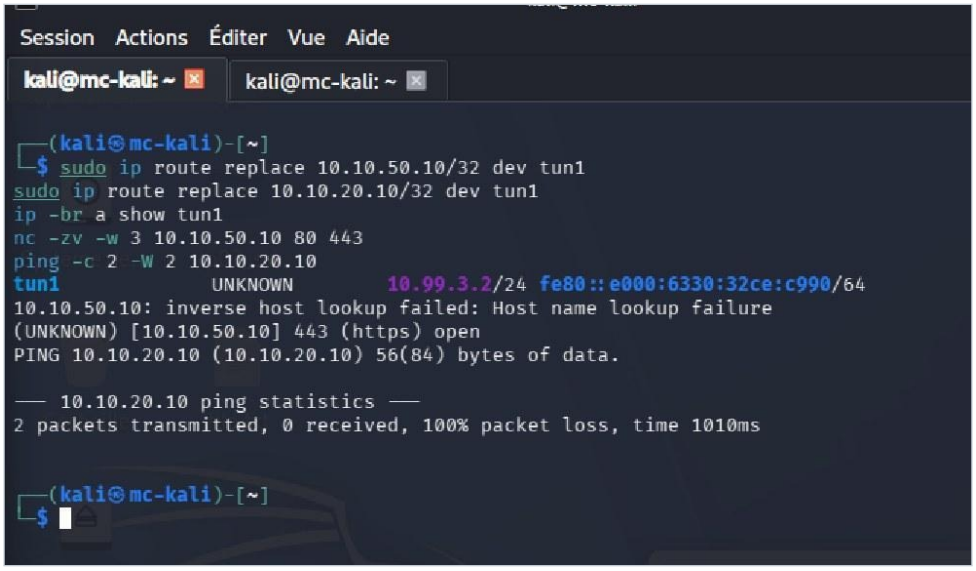
— 10.10.20.10 ping statistics —
3 packets transmitted, 0 received, 100% packet loss, time 2042ms

HTTP/1.1 200 OK
Server: nginx/1.28.3 (Ubuntu)
Date: Thu, 22 Oct 2026 15:04:46 GMT
Content-Type: text/html
Content-Length: 57
Last-Modified: Fri, 16 Oct 2026 12:15:06 GMT
Connection: keep-alive
ETag: "6ad2154a-39"
Accept-Ranges: bytes

PING 10.10.10.1 (10.10.10.1) 56(84) bytes of data.

— 10.10.10.1 ping statistics —
3 packets transmitted, 0 received, 100% packet loss, time 2042ms

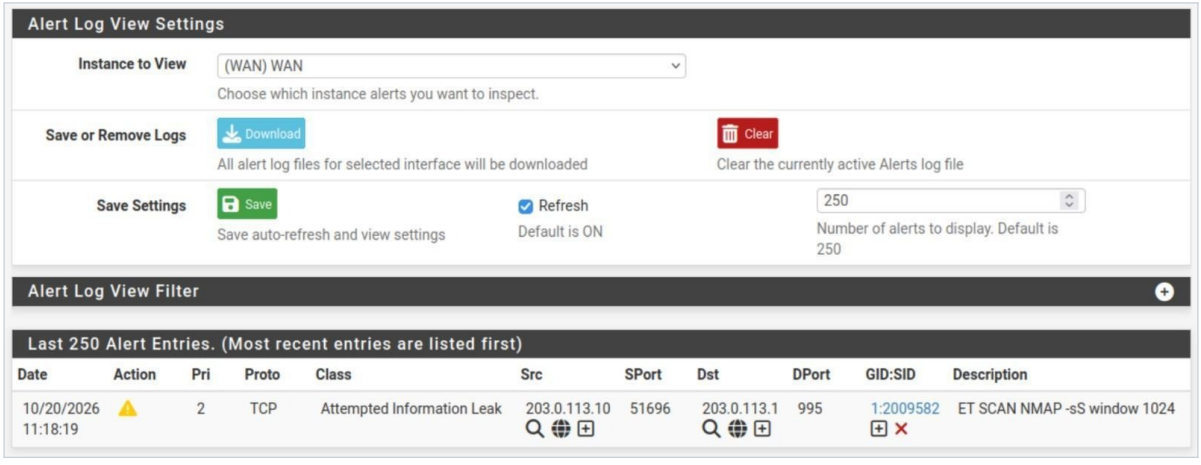
┌──(kali㉿mc-kali)-[~]
└─$
```

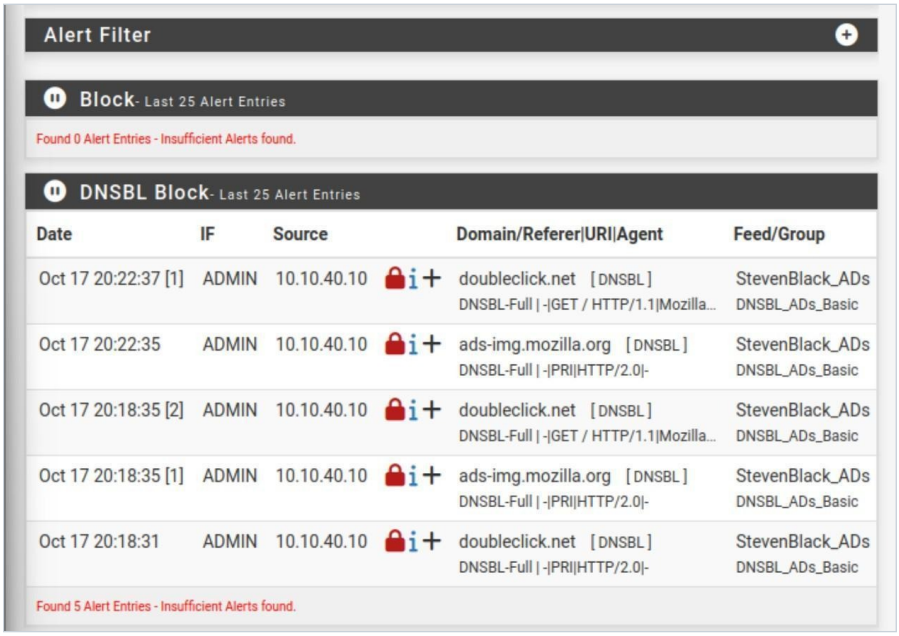


5.4 Contrôle applicatif

pfSense CE ne propose pas d'identification des applications au niveau 7 comparable à l'App-ID d'un pare-feu de nouvelle génération. Le contrôle applicatif repose donc sur trois mécanismes complémentaires.

- Suricata analyse le trafic du WAN (règles ET Open, catégorie emerging-scan) et de la DMZ (règle personnalisée de test). Il fonctionne en mode IDS, sans blocage, pour qu'un faux positif ne coupe pas le portail. Le blocage reste assuré par le filtrage. Un scan nmap depuis Kali déclenche l'alerte ET SCAN NMAP, transmise à Wazuh.
- pfBlockerNG bloque les adresses de mauvaise réputation (listes CINS, ET Block, Spamhaus DROP, Feodo) et, via le résolveur DNS, les domaines publicitaires ou malveillants (DNSBL), qui sont redirigés vers l'adresse puits 10.10.250.1, alors qu'un domaine légitime est résolu normalement.
- ntopng identifie les protocoles applicatifs (nDPI) sur la zone ADMIN et donne une visibilité sur les flux.





Alert Filter

Block - Last 25 Alert Entries

Found 0 Alert Entries - Insufficient Alerts found.

DNSBL Block - Last 25 Alert Entries

Date	IF	Source	Domain/Referer|URI|Agent	Feed/Group
Oct 17 20:22:37 [1]	ADMIN	10.10.40.10	doubleclick.net [DNSBL] DNSBL-Full | -|GET / HTTP/1.1|Mozilla...	StevenBlack_ADs DNSBL_ADs_Basic
Oct 17 20:22:35	ADMIN	10.10.40.10	ads-img.mozilla.org [DNSBL] DNSBL-Full | -|PRI|HTTP/2.0|-	StevenBlack_ADs DNSBL_ADs_Basic
Oct 17 20:18:35 [2]	ADMIN	10.10.40.10	doubleclick.net [DNSBL] DNSBL-Full | -|GET / HTTP/1.1|Mozilla...	StevenBlack_ADs DNSBL_ADs_Basic
Oct 17 20:18:35 [1]	ADMIN	10.10.40.10	ads-img.mozilla.org [DNSBL] DNSBL-Full | -|PRI|HTTP/2.0|-	StevenBlack_ADs DNSBL_ADs_Basic
Oct 17 20:18:31	ADMIN	10.10.40.10	doubleclick.net [DNSBL] DNSBL-Full | -|PRI|HTTP/2.0|-	StevenBlack_ADs DNSBL_ADs_Basic

Found 5 Alert Entries - Insufficient Alerts found.

```
xubuntu@admin:~$ nslookup -type=A doubleclick.net 10.10.40.1
nslookup -type=A archive.ubuntu.com 10.10.40.1
Server:         10.10.40.1
Address:        10.10.40.1#53

Name:   doubleclick.net
Address: 10.10.250.1

Server:         10.10.40.1
Address:        10.10.40.1#53

Non-authoritative answer:
Name:   archive.ubuntu.com
Address: 91.189.91.82
Name:   archive.ubuntu.com
Address: 91.189.92.24
```

```
[ Spamhaus_Drop_v4 ]          exists.

===[  Aliastables / Rules  ]==========================================

No changes to Firewall rules, skipping Filter Reload
No Changes to Aliases, Skipping pfctl Update

Saving config changes... completed
===[ FINAL Processing ]===================================

   [ Original IP count   ]  [ 18914 ]

   [ Final IP Count  ]  [ 17115 ]

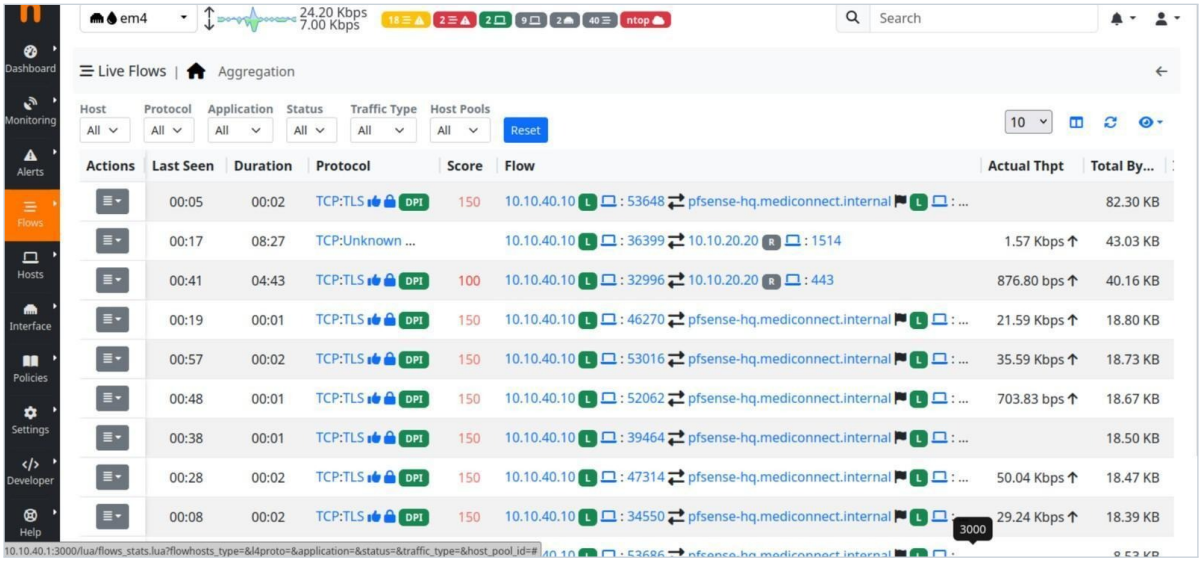

===[ Deny List IP Counts ]=========================

   17115 total
   15000 /var/db/pfblockerng/deny/CINS_army_v4.txt
    1699 /var/db/pfblockerng/deny/ET_Block_v4.txt
     392 /var/db/pfblockerng/deny/ET_Comp_v4.txt
      12 /var/db/pfblockerng/deny/Spamhaus_Drop_v4.txt
      11 /var/db/pfblockerng/deny/ISC_Block_v4.txt
       1 /var/db/pfblockerng/deny/Abuse_Feodo_C2_v4.txt

===[ DNSBL Domain/IP Counts ] ================================

   73633 /var/db/pfblockerng/dnsbl/StevenBlack_ADs.txt

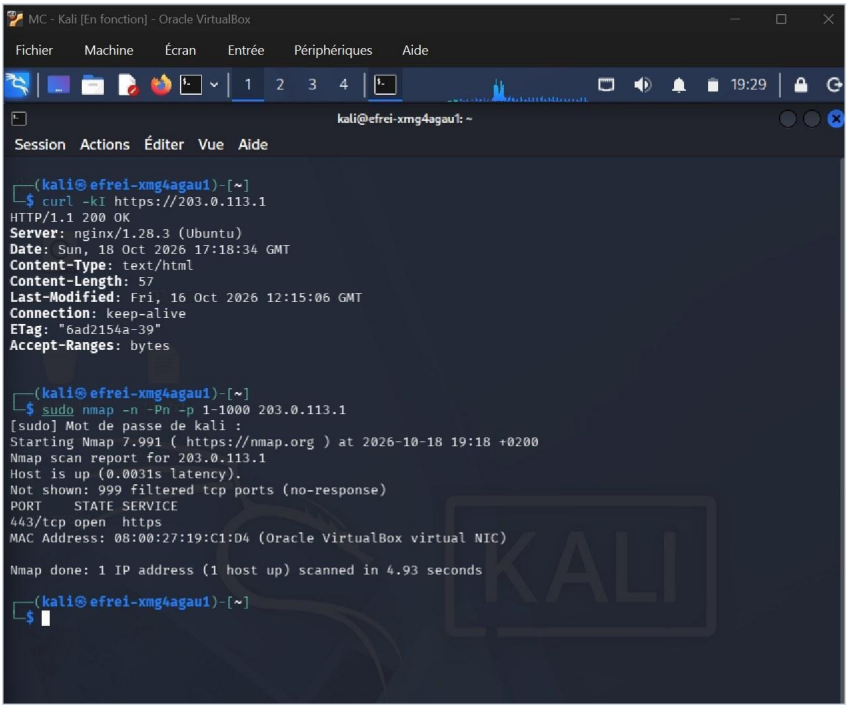
==================[ IPv4/6 Last Updated List Summary ]=============
```

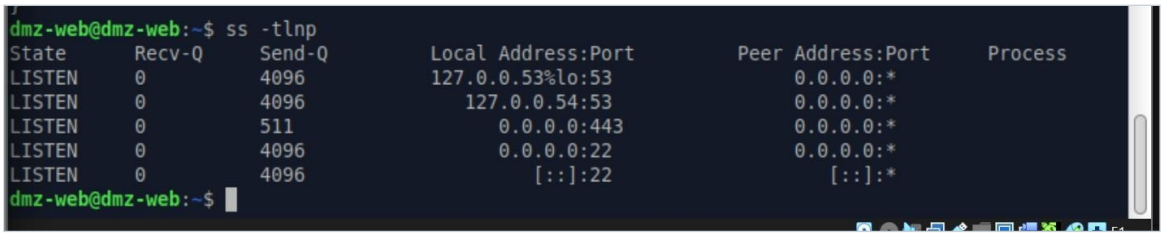

em4
24.20 Kbps
7.00 Kbps
Search
Live Flows | Aggregation
Host
Protocol
Application
Status
Traffic Type
Host Pools
Reset
Actions
Last Seen
Duration
Protocol
Score
Flow
Actual Thpt
Total By...
00:05 00:02 TCP:TLS DPI 150 10.10.40.10 : 53648 pfsense-hq.mediconnect.internal : ... 82.30 KB
00:17 08:27 TCP:Unknown ... 10.10.40.10 : 36399 10.10.20.20 : 1514 1.57 Kbps 43.03 KB
00:41 04:43 TCP:TLS DPI 100 10.10.40.10 : 32996 10.10.20.20 : 443 876.80 bps 40.16 KB
00:19 00:01 TCP:TLS DPI 150 10.10.40.10 : 46270 pfsense-hq.mediconnect.internal : ... 21.59 Kbps 18.80 KB
00:57 00:02 TCP:TLS DPI 150 10.10.40.10 : 53016 pfsense-hq.mediconnect.internal : ... 35.59 Kbps 18.73 KB
00:48 00:01 TCP:TLS DPI 150 10.10.40.10 : 52062 pfsense-hq.mediconnect.internal : ... 703.83 bps 18.67 KB
00:38 00:01 TCP:TLS DPI 150 10.10.40.10 : 39464 pfsense-hq.mediconnect.internal : ... 18.50 KB
00:28 00:02 TCP:TLS DPI 150 10.10.40.10 : 47314 pfsense-hq.mediconnect.internal : ... 50.04 Kbps 18.47 KB
00:08 00:02 TCP:TLS DPI 150 10.10.40.10 : 34550 pfsense-hq.mediconnect.internal : ... 29.24 Kbps 18.39 KB
3000
10.10.40.1:3000/lua/flows_stats.lua?flowhosts_type=&l4proto=&application=&status=&traffic_type=&host_pool_id=#

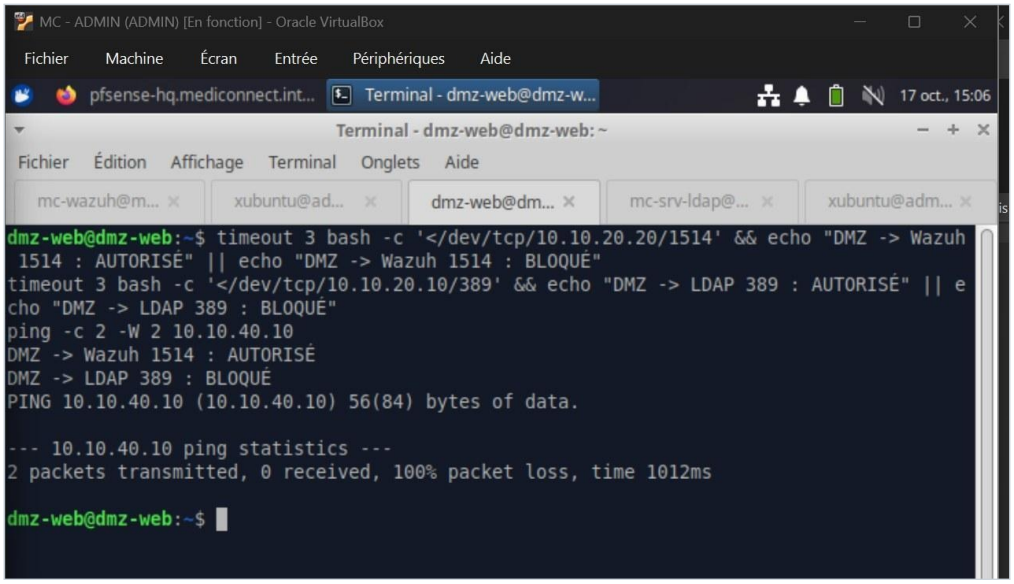
6 Protection de la DMZ

La DMZ héberge le seul service exposé à Internet. Elle est traitée comme une zone susceptible d'être compromise. Les mesures ci-dessous limitent ce qu'un attaquant pourrait atteindre depuis le portail.

- L'exposition est minimale, avec une seule redirection NAT (WAN:443 vers 10.10.30.10:443). Un scan depuis Internet ne révèle que ce port.
- Le portail est en HTTPS uniquement. nginx n'écoute que sur le port 443, avec TLS 1.2 et 1.3, et aucun service n'est proposé en HTTP.
- La DMZ est isolée et ne peut initier que LDAPS vers l'annuaire et la connexion de l'agent Wazuh. Tout autre flux vers les zones internes ou vers le pare-feu est bloqué et journalisé (règles D3 et P1).
- Pour la surveillance, Suricata analyse l'interface DMZ et un agent Wazuh est installé sur dmz-web.







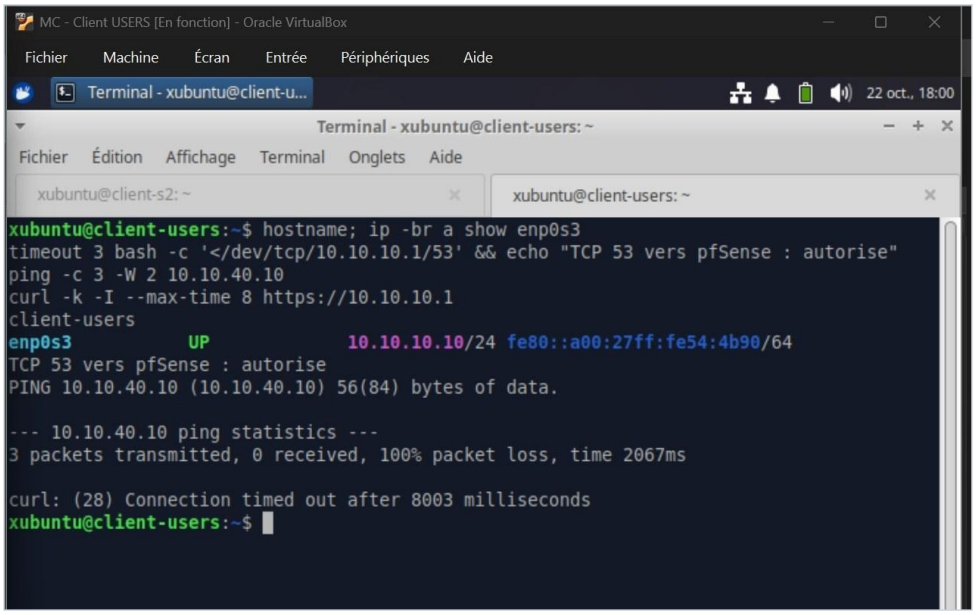
Action	Time	Interface	Rule	Source	Destination	Protocol
✕	Oct 16 14:07:01	DMZ	P1 - Block DMZ vers pfSense (1792151021)	10.10.30.10	10.10.30.1	ICMP
✕	Oct 16 14:07:00	DMZ	P1 - Block DMZ vers pfSense (1792151021)	10.10.30.10	10.10.30.1	ICMP
✕	Oct 16 14:06:59	DMZ	P1 - Block DMZ vers pfSense (1792151021)	10.10.30.10	10.10.30.1	ICMP
✕	Oct 16 14:06:42	DMZ	D3 - Block DMZ vers zones internes (1792075086)	10.10.30.10	10.10.40.10	ICMP
✕	Oct 16 14:06:41	DMZ	D3 - Block DMZ vers zones internes (1792075086)	10.10.30.10	10.10.40.10	ICMP
✕	Oct 16 14:06:40	DMZ	D3 - Block DMZ vers zones internes (1792075086)	10.10.30.10	10.10.40.10	ICMP

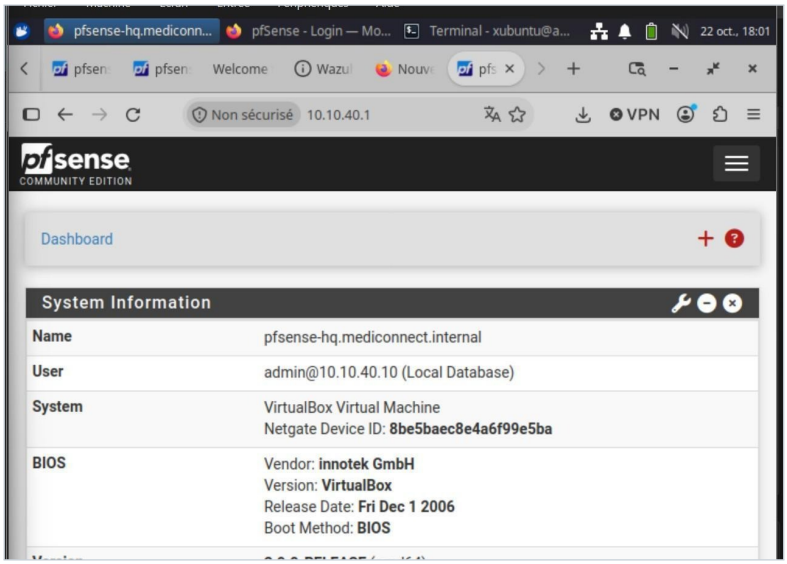
7 Sécurisation de l'administration

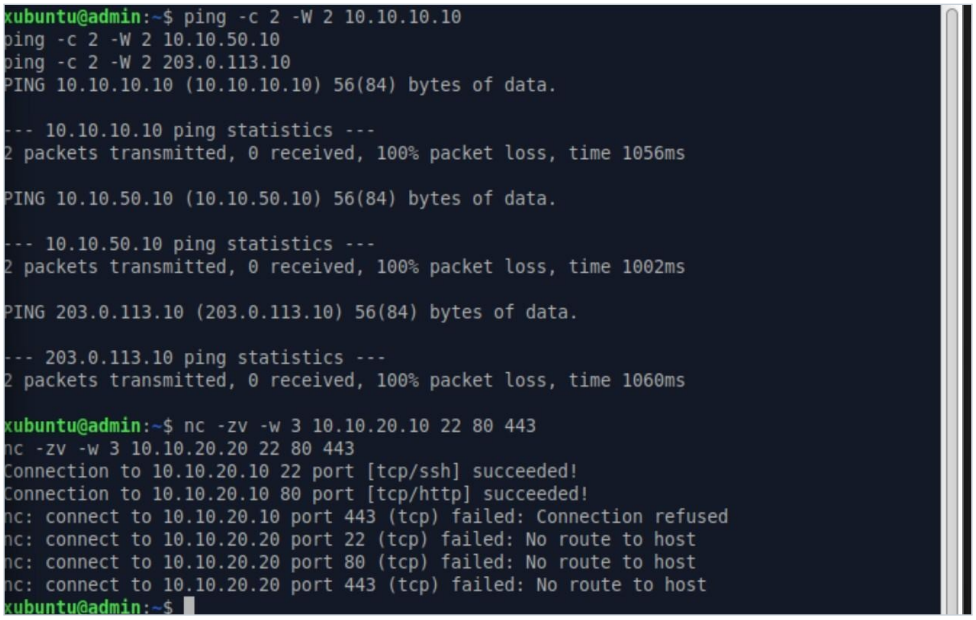
Les flux d'administration sont séparés des flux utilisateurs. Seule la zone ADMIN (bastion 10.10.40.10) peut joindre l'interface web de pfSense en HTTPS. Depuis USERS, DMZ, SRV et DEMO, toute connexion vers le pare-feu est refusée. Un utilisateur du LAN ne peut donc pas administrer les équipements. Depuis client-users, le bastion et l'interface web restent injoignables.

La zone ADMIN elle-même est restreinte (règles en section 5.2). Elle ne dispose que du DNS et du NTP vers pfSense (A1, A2), de ntopng (A3), du SSH, du web et du ping vers ADMIN, SRV et DMZ (A4 à A6). La règle A7 bloque et journalise tout le reste, y compris l'accès à Internet, à USERS et à DEMO.

Ce modèle de bastion concentre les accès privilégiés sur un poste unique, plus simple à durcir et à surveiller. L'interface de pfSense n'est servie qu'en HTTPS et la règle anti-blocage (anti-lockout) de pfSense ne s'applique qu'à l'interface ADMIN.






xubuntu@admin:~$ ping -c 2 -W 2 10.10.10.10
ping -c 2 -W 2 10.10.50.10
ping -c 2 -W 2 203.0.113.10
PING 10.10.10.10 (10.10.10.10) 56(84) bytes of data.
--- 10.10.10.10 ping statistics ---
2 packets transmitted, 0 received, 100% packet loss, time 1056ms
PING 10.10.50.10 (10.10.50.10) 56(84) bytes of data.
--- 10.10.50.10 ping statistics ---
2 packets transmitted, 0 received, 100% packet loss, time 1002ms
PING 203.0.113.10 (203.0.113.10) 56(84) bytes of data.
--- 203.0.113.10 ping statistics ---
2 packets transmitted, 0 received, 100% packet loss, time 1060ms
xubuntu@admin:~$ nc -zv -w 3 10.10.20.10 22 80 443
nc -zv -w 3 10.10.20.20 22 80 443
Connection to 10.10.20.10 22 port [tcp/ssh] succeeded!
Connection to 10.10.20.10 80 port [tcp/http] succeeded!
nc: connect to 10.10.20.10 port 443 (tcp) failed: Connection refused
nc: connect to 10.10.20.20 port 22 (tcp) failed: No route to host
nc: connect to 10.10.20.20 port 80 (tcp) failed: No route to host
nc: connect to 10.10.20.20 port 443 (tcp) failed: No route to host
xubuntu@admin:~$

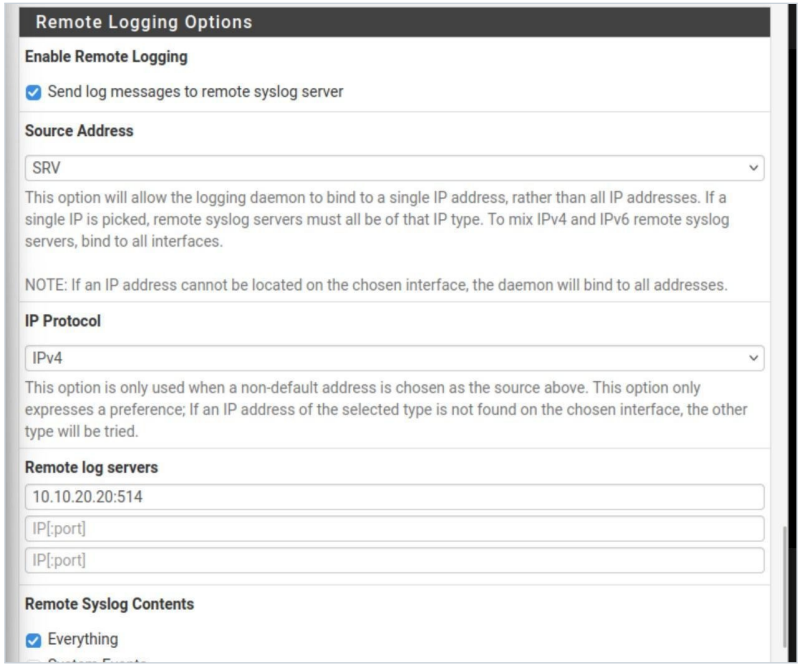
8 Journalisation et supervision

Le SIEM Wazuh (10.10.20.20, zone SRV) centralise deux sources.

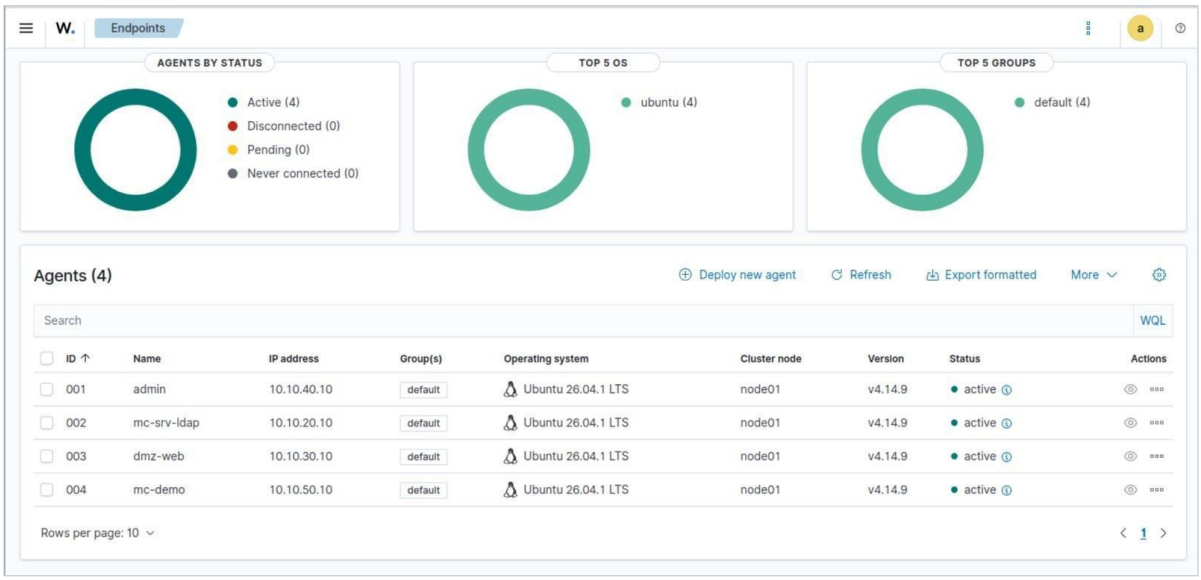
- pfSense-HQ envoie tous ses journaux en syslog (UDP 514), c'est-à-dire les blocages du pare-feu (règles avec journalisation activée), les alertes Suricata, les authentifications, le VPN et le système.
- Les agents Wazuh installés sur le bastion, mc-srv-ldap, dmz-web et mc-demo remontent les journaux et l'intégrité des machines.

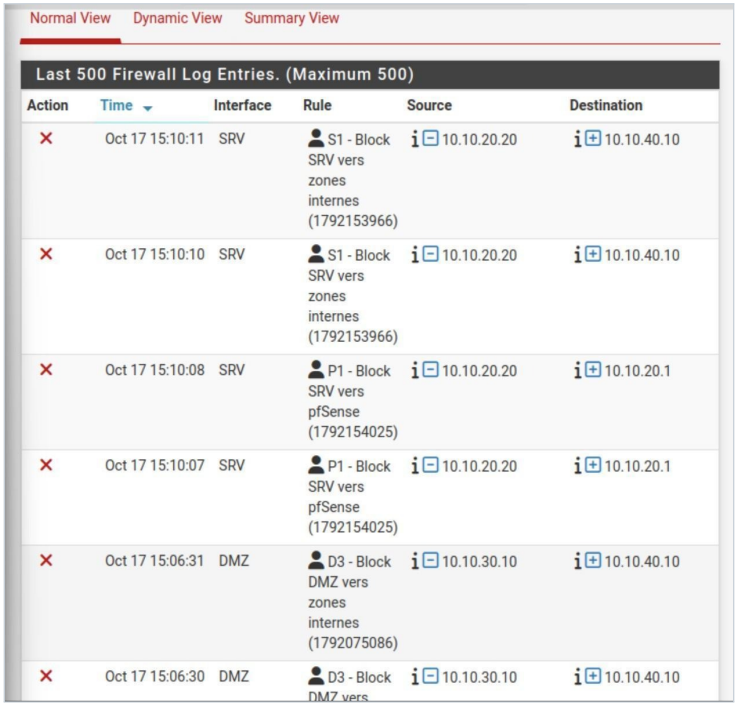
Source	Événements	Transport	Exploitation dans Wazuh
Pare-feu pfSense	Flux bloqués par les règles journalisées et par le refus par défaut	Syslog UDP 514	Décodeur personnalisé, règle 100101
Suricata (pfSense)	Alertes IDS du WAN et de la DMZ	Syslog UDP 514	Décodeur personnalisé, règle 100201
pfSense (système, VPN)	Connexions et authentifications VPN, événements système	Syslog UDP 514	Conservation et recherche
Agents (4 machines)	Journaux système, connexions SSH, intégrité des fichiers	TCP 1514, chiffré	Règles Wazuh par défaut

Des décodeurs et des règles personnalisés transforment les messages pfSense en alertes exploitables. La règle 100101 signale un blocage du pare-feu (niveau 5) et la règle 100201 une alerte Suricata (niveau 6). Les journaux locaux de pfSense étant circulaires, c'est l'indexeur Wazuh qui assure la conservation. En production, une durée de rétention (par exemple 90 jours en ligne puis archivage) serait fixée selon les exigences d'hébergement des données de santé.



```
mc-wazuh@mc-wazuh:~$ sudo tcpdump -ni enp0s3 -c 5 udp port 514
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode
listening on enp0s3, link-type EN10MB (Ethernet), snapshot length 262144 bytes
14:20:28.289032 IP 10.10.20.1.514 > 10.10.20.20.514: SYSLOG cron.info, length: 75
14:21:26.248895 IP 10.10.20.1.514 > 10.10.20.20.514: SYSLOG local0.info, length: 148
14:21:27.246031 IP 10.10.20.1.514 > 10.10.20.20.514: SYSLOG local0.info, length: 148
14:21:28.287131 IP 10.10.20.1.514 > 10.10.20.20.514: SYSLOG local0.info, length: 148
14:21:28.287781 IP 10.10.20.1.514 > 10.10.20.20.514: SYSLOG cron.info, length: 75
5 packets captured
5 packets received by filter
0 packets dropped by kernel
mc-wazuh@mc-wazuh:~$
```





```
mc-wazuh@mc-wazuh:~$ sudo /var/ossec/bin/wazuh-logtest
[sudo] password for mc-wazuh:
Starting wazuh-logtest v4.14.9
Type one log per line

Oct 17 14:24:58 filterlog[35662]: 1,100,,1792075086,em2,match,block,in,4,0x0,,64,42022,
0,DF,1,icmp,84,10.10.30.10,10.10.40.10,request,26499,164

**Phase 1: Completed pre-decoding.
        full event: 'Oct 17 14:24:58 filterlog[35662]: 1,100,,1792075086,em2,match,bloc
k,in,4,0x0,,64,42022,0,DF,1,icmp,84,10.10.30.10,10.10.40.10,request,26499,164'
        timestamp: 'Oct 17 14:24:58'
        hostname: 'filterlog[35662]:'

**Phase 2: Completed decoding.
        name: 'pf-nohost'
        action: 'block'
        dstip: '10.10.40.10'
        dstport: '26499'
        id: '1792075086'
        protocol: 'icmp'
        srcip: '10.10.30.10'
        srcport: ''

**Phase 3: Completed filtering (rules).
        id: '100101'
        level: '5'
        description: 'pfSense firewall drop event.'
        groups: '['pfsense', 'firewall_block']'
        firedtimes: '1'
        gpg13: '['4.12']'
        hipaa: '['164.312.a.1']'
        mail: 'False'
        nist_800_53: '['SC.7']'
        pci_dss: '['1.4']'
        tsc: '['CC6.7', 'CC6.8']'
**Alert to be generated.
```

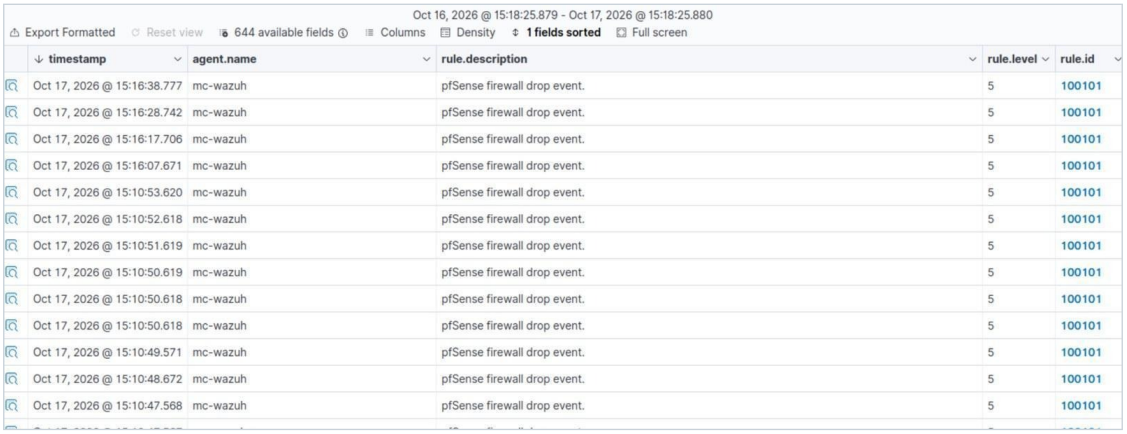
```
Starting wazuh-logtest v4.14.9
Type one log per line

Oct 17 16:27:43 suricata[23106]: [1:9000001:1] TEST MediConnect ICMP [Classification: (
null)] [Priority: 3] {ICMP} 10.10.40.10:8 -> 10.10.30.10:0

**Phase 1: Completed pre-decoding.
        full event: 'Oct 17 16:27:43 suricata[23106]: [1:9000001:1] TEST MediConnect IC
MP [Classification: (null)] [Priority: 3] {ICMP} 10.10.40.10:8 -> 10.10.30.10:0'
        timestamp: 'Oct 17 16:27:43'
        hostname: 'suricata[23106]:'

**Phase 2: Completed decoding.
        name: 'suricata-nohost'
        class: '(null)'
        dstip: '10.10.30.10'
        dstport: '0'
        gid: '1'
        id: '9000001'
        priority: '3'
        protocol: 'ICMP'
        rev: '1'
        signature: 'TEST MediConnect ICMP'
        srcip: '10.10.40.10'
        srcport: '8'

**Phase 3: Completed filtering (rules).
        id: '100201'
        level: '6'
        description: 'Suricata alert: TEST MediConnect ICMP'
        groups: '['suricata', 'ids', 'attack']'
        firedtimes: '1'
        mail: 'False'
**Alert to be generated.
```



Oct 16, 2026 @ 15:18:25.879 - Oct 17, 2026 @ 15:18:25.880

Export Formatted | Reset view | 644 available fields | Columns | Density | 1 fields sorted | Full screen

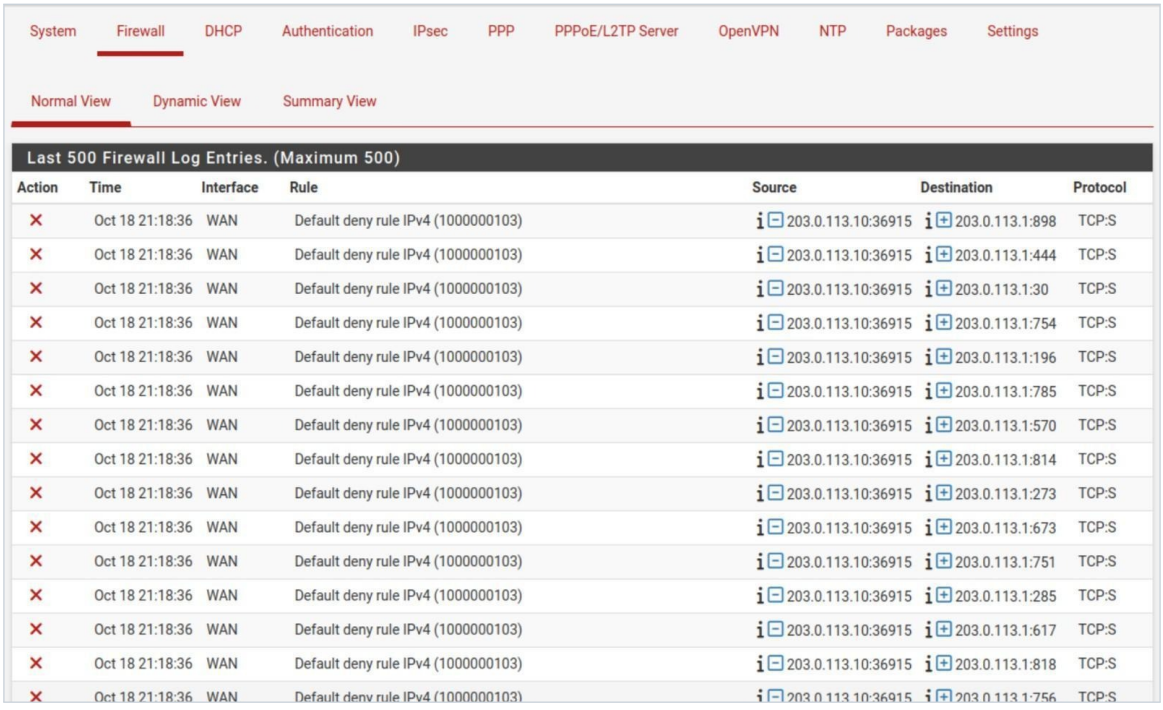
timestamp	agent.name	rule.description	rule.level	rule.id
Oct 17, 2026 @ 15:16:38.777	mc-wazuh	pfSense firewall drop event.	5	100101
Oct 17, 2026 @ 15:16:28.742	mc-wazuh	pfSense firewall drop event.	5	100101
Oct 17, 2026 @ 15:16:17.706	mc-wazuh	pfSense firewall drop event.	5	100101
Oct 17, 2026 @ 15:16:07.671	mc-wazuh	pfSense firewall drop event.	5	100101
Oct 17, 2026 @ 15:10:53.620	mc-wazuh	pfSense firewall drop event.	5	100101
Oct 17, 2026 @ 15:10:52.618	mc-wazuh	pfSense firewall drop event.	5	100101
Oct 17, 2026 @ 15:10:51.619	mc-wazuh	pfSense firewall drop event.	5	100101
Oct 17, 2026 @ 15:10:50.619	mc-wazuh	pfSense firewall drop event.	5	100101
Oct 17, 2026 @ 15:10:50.618	mc-wazuh	pfSense firewall drop event.	5	100101
Oct 17, 2026 @ 15:10:50.618	mc-wazuh	pfSense firewall drop event.	5	100101
Oct 17, 2026 @ 15:10:49.571	mc-wazuh	pfSense firewall drop event.	5	100101
Oct 17, 2026 @ 15:10:48.672	mc-wazuh	pfSense firewall drop event.	5	100101
Oct 17, 2026 @ 15:10:47.568	mc-wazuh	pfSense firewall drop event.	5	100101

9 Tests réalisés

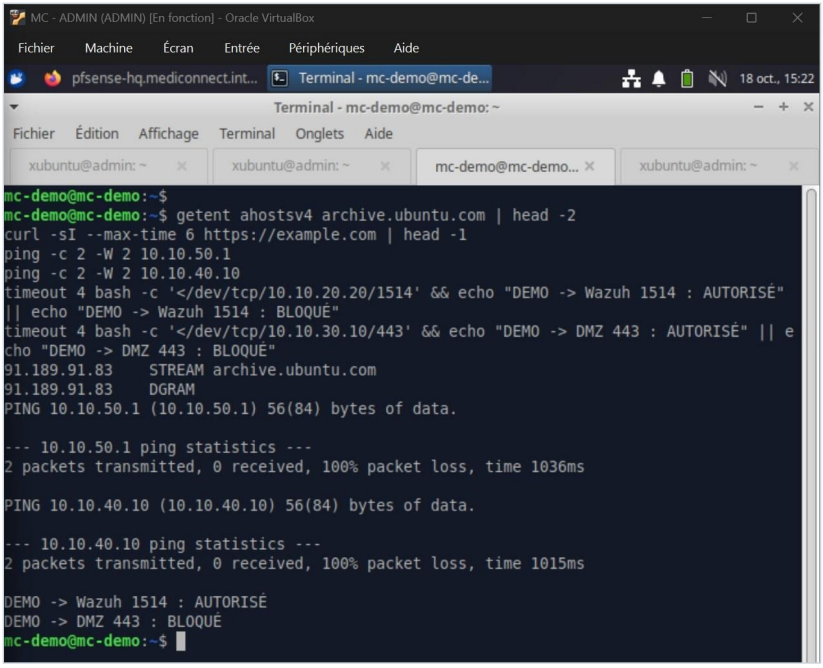
Chaque exigence du sujet a été vérifiée par un test dont le résultat est capturé. Le tableau ci-dessous indique la section où se trouve la preuve.

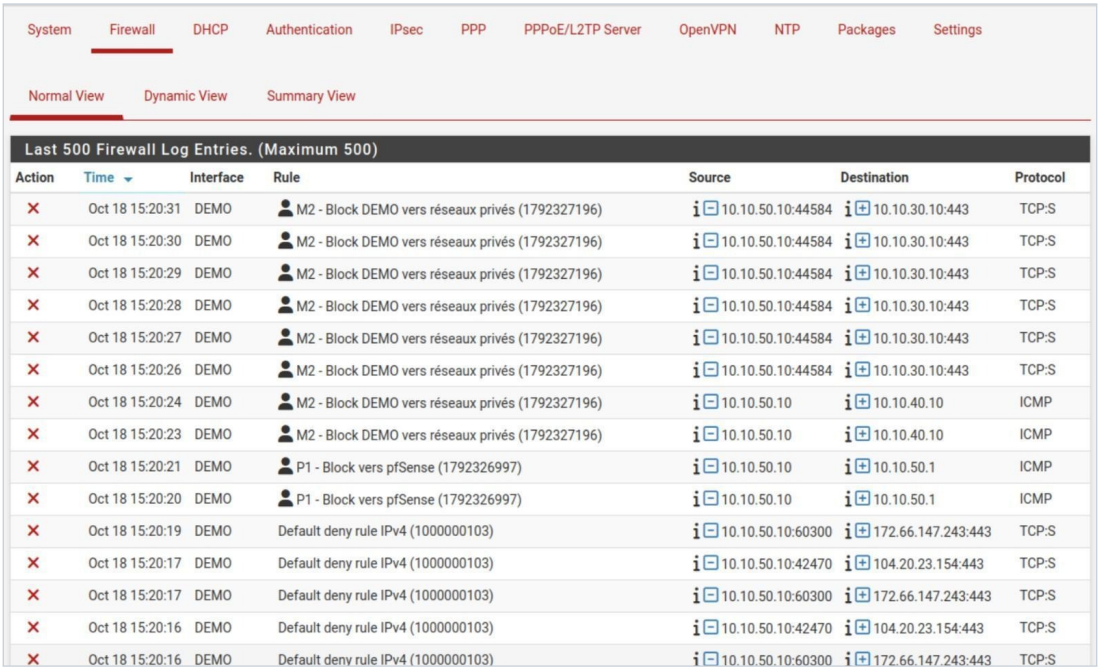
Test	Méthode	Attendu	Obtenu	Section
Patient vers le SI interne	Depuis Kali, curl sur le portail puis nmap -p 1-1000 203.0.113.1	Portail seul accessible	200 OK, seul le port 443 est ouvert	6, 9
Isolement de la DMZ	Depuis dmz-web, TCP 1514 vers Wazuh, TCP 389 vers LDAP et ping vers ADMIN	Seul l'agent Wazuh passe	Conforme	6
Médecin sans certificat	curl sur /medecin/ sans puis avec certificat	Refus puis accès	403 puis 200	4.4.4
Poste USERS vers ADMIN	Depuis client-users, ping 10.10.40.10 et curl https://10.10.10.1	Bloqué	100 % de perte, timeout	7
Profils VPN	Pour alice, eva et farid, une ressource autorisée et une interdite	Accès limité au profil	Conforme pour les trois profils	5.3
DEMO vers production	Depuis mc-demo, ping vers ADMIN, TCP 443 vers la DMZ et TCP 1514 vers Wazuh	Seul l'agent Wazuh passe	Conforme	9
Site 2 vers siège	Depuis client-s2, ping vers SRV puis vers ADMIN	SRV seul joignable	0 % puis 100 % de perte	4.1
Durcissement ADMIN	Depuis le bastion, DNS, SSH et web, puis USERS, DEMO et Internet	Seuls A1 à A6 passent	Conforme	7
Détection	Ping vers la DMZ (règle Suricata de test), scan nmap du WAN	Alerte Suricata puis Wazuh	Alertes Suricata et règle Wazuh 100201	5.4, 9

Le scan depuis Internet montre que seules les tentatives vers le port 443 aboutissent. Les autres sont rejetées par le refus par défaut du WAN.



Depuis la DEMO, la production est bloquée et seul l'agent Wazuh passe. Les blocages sont journalisés par les règles M2 et P1.





Un ping vers la DMZ déclenche la règle Suricata de test, puis l'alerte est reçue et classée par Wazuh (règle 100201).

Last 250 Alert Entries. (Most recent entries are listed first)

Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GID:SID	Description
10/17/2026 16:23:57	⚠	3	ICMP	Not Assigned	10.10.40.10	8	10.10.30.10	0	1:9000001	TEST MediConnect ICMP
10/17/2026 16:23:56	⚠	3	ICMP	Not Assigned	10.10.40.10	8	10.10.30.10	0	1:9000001	TEST MediConnect ICMP
10/17/2026 16:23:55	⚠	3	ICMP	Not Assigned	10.10.40.10	8	10.10.30.10	0	1:9000001	TEST MediConnect ICMP

5 hits

Oct 16, 2026 @ 16:35:26.990 - Oct 17, 2026 @ 16:35:26.990

Export Formatted | Reset view | 648 available fields | Columns | Density | **1 fields sorted** | Full screen

timestamp	agent.name	rule.description	rule.level	rule.id
Oct 17, 2026 @ 16:33:27.333	mc-wazuh	Suricata alert: TEST MediConnect ICMP	6	100201
Oct 17, 2026 @ 16:33:26.330	mc-wazuh	Suricata alert: TEST MediConnect ICMP	6	100201
Oct 17, 2026 @ 16:33:25.352	mc-wazuh	Suricata alert: TEST MediConnect ICMP	6	100201
Oct 17, 2026 @ 16:33:24.381	mc-wazuh	Suricata alert: TEST MediConnect ICMP	6	100201
Oct 17, 2026 @ 16:33:23.392	mc-wazuh	Suricata alert: TEST MediConnect ICMP	6	100201

10 Limites de la solution

- Le contrôle applicatif est limité car pfSense CE n'a pas d'App-ID comme un pare-feu de nouvelle génération, et Suricata fonctionne seulement en détection, il ne bloque rien.
- Il n'y a pas de double authentification. L'accès distant demande un certificat et un mot de passe, mais pas de code TOTP. On pourrait en ajouter un avec FreeRADIUS.
- Il n'y a pas de liste de révocation. MediConnect-CA ne publie pas de CRL, donc un certificat volé resterait accepté. Il faudrait en créer une et l'associer aux instances OpenVPN.
- Avoir une instance OpenVPN par profil est simple à lire, mais ça ne marcherait plus avec beaucoup de groupes. Dans ce cas, il vaudrait mieux passer par RADIUS pour attribuer les adresses par groupe.
- L'administration n'est pas encore assez durcie. Les comptes pfSense sont locaux, le SSH se fait par mot de passe et pas par clé, et LAM est servi en HTTP dans la zone SRV.
- Les logs ne sont pas assez protégés. Le syslog passe en UDP, sans chiffrement ni authentification, et la durée de conservation n'est pas définie. Il faudrait passer en TLS.
- Il n'y a aucune redondance. Chaque site a un seul pare-feu, sans CARP, et Wazuh tourne sur une seule machine avec peu de ressources.
- Internet est simulé, donc j'ai désactivé le blocage des réseaux privés et bogon sur les WAN. Les signatures et les listes ne sont mises à jour que de temps en temps.
- Il n'y a pas de serveur NTP de référence. L'horloge de pfSense a dérivé, ce qui a coupé des connexions OpenVPN et décalé des horodatages et cela après chaque reboot.

11 Conclusion

La maquette répond aux objectifs du sujet. Les deux sites sont reliés par un tunnel IPsec filtré, les salariés et les commerciaux accèdent à distance selon leur identité, les patients ne voient que le portail HTTPS et les médecins doivent présenter un certificat. La production est séparée de la démonstration, l'administration est réservée à une zone dédiée et les événements de sécurité sont centralisés dans Wazuh. Les principales améliorations concernent l'authentification (TOTP, clés SSH, révocation), la haute disponibilité et le passage du contrôle applicatif de la détection au blocage.